Information Security Audit Questionnaire

CIT.017 Information Assurance and Security – Final Project
Ateneo de Zamboanga University, College of Science and Information Technology, Computer Science Department
Prepared by: Shariff Isirani, Dorothy Ubag, Jean Caparas

Good day po, Ma'am Mary! Thank you for agreeing to be part of our project. This questionnaire will help us understand how your office handles its information, records, and tools. It is for class purposes only. We are not evaluating any person, only how information is handled. Please do not write actual passwords or personal data in your answers. You may skip any question you are not comfortable answering, and you may tell us if there is anything you would like us to leave out of the report. Short answers are fine. Please type your answers on the lines marked Answer:

Respondent Information

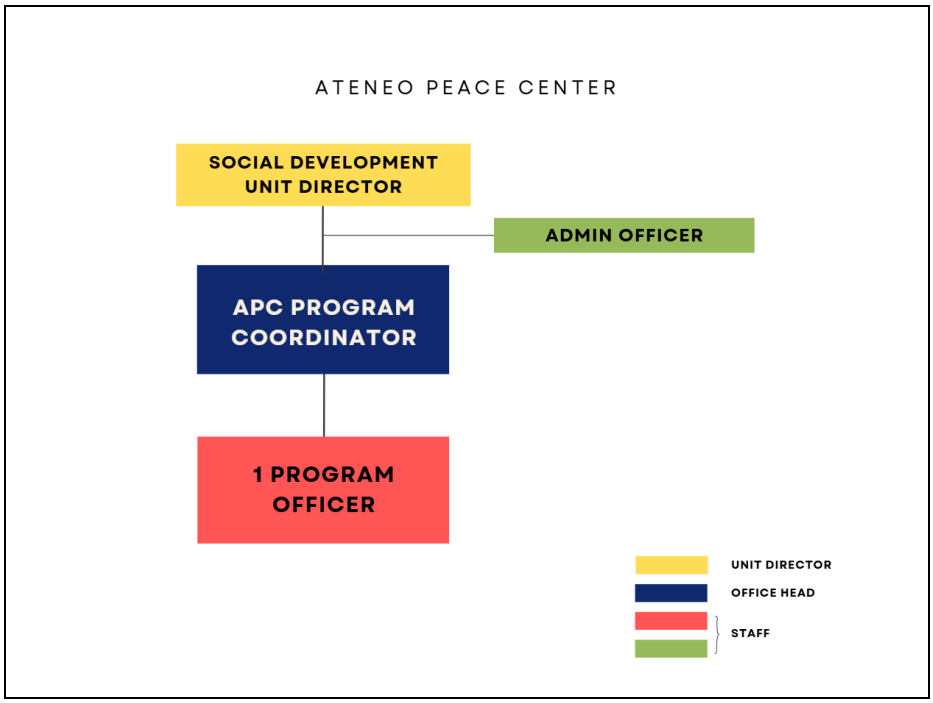
Name: Mary Elizabeth S Apolonio
Position: Program Coordinator
Office/Unit (official name): Ateneo Peace Center/Social Development Unit
Date answered: October 30, 2026

A. ORGANIZATION PROFILE (Section II)

1. What is the official name of your office, and what does it stand for?
Answer: APC or Ateneo Peace Center (formerly it was Ateneo Peace Institute)

2. Who is in your office and what are their roles? (An organizational chart is welcome if you have one.)
Answer: Current personnel:

- Mary Elizabeth Apolonio, Program Coordinator
- Fatima Raiza Ibrahim, Program Officer



**Note that our Admin Officer is the Admin/Support staff of the Social Development Office for now.*

3. What are the main functions or services of your office?
Answer: The Ateneo Peace Center empowers communities to build lasting peace through peace advocacy and communication, peace education, and research. It aims to promote transformative peace building mechanisms rooted from Ignatian spirituality, cultural sensitivity, and open dialogue.
What we do:

- Peace Advocacy: The aim of this program is to strengthen more effective peace building and conflict transformation mechanisms and improve peace, order, and harmony within the Ateneo community and across local communities.
- Peace Education: The program aims to equip individuals with knowledge, skills, and attitudes to build a culture of peace. This includes integrating peace values into existing curricula and co-curricular activities across Basic and Higher Education levels; designing and delivering educational programs on conflict resolution, nonviolence, and human rights; and training educators and community leaders.
- SALAAM-AdZU Organization: The SALAAM-AdZU Organization is the student volunteer arm of the Ateneo Peace Center (APC) of the Ateneo de Zamboanga University. This program empowers students to dive deeper into the culture of peace, providing a platform for meaningful engagement with the Ateneo community and offering hands-on experience in peace-related activities.

4. What are your most important business processes and the people involved based on each processes (e.g., training requests, partner coordination, reporting)? For each one, who is involved, what information is used, and what tool or system is used, and the specific

inputs/outputs

(EXAMPLE ONLY:) u can use the table po:

Major Business Process	*People Involved*	*Information Used*	*Information System Used*	*Inputs*	*Outputs*
Financial Documentation	Admin Officer, APC Personnel	Staff records, contracts, and evaluations	Google Drive, Email, Physical Records	Financial documents and payment requests	Maintained financial records

Answer:

B. INFORMATION ASSETS (Section III)
5. What kinds of information does your office keep (staff records, certificates, partner details, reports, evaluations, etc.)?

(Please add specific data included per assets and the personnel assigned / responsible owner)

u can answer here on the table po:

Information Asset	*Description*	*Data Included (SPECIFIC DATA HERE)*	*Responsible Owner*	*System*
Certificates and Recognitions	Records of awards, recognitions, and expressions of appreciation received by the office and its personnel			Physical Records and Google Drive
External Partner Inventory	Records of external organizations and institutions that collaborate or			Physical Records and Google Drive

	maintain partnerships with the office			
Monitoring and Evaluation Reports	Documents maintained for monitoring and evaluating the office's programs, projects, and activities		Office as a Whole	Physical Records and Google Drive
Staff Records	Records containing employment details and performance-related information of office personnel			Physical Records and Google Drive
Accomplishment Reports	Documents highlighting the outcomes and accomplishments of the office's activities		Office as a Whole	Physical Records and Google Drive
Financial Documents	Records of the office's financial transactions and related expenses		Admin Officer	Physical Records and Google Drive
Formal Correspondence	Official correspondence received by the office from individuals, institutions, and external organizations			Physical Records and Google Drive
Books and Publications	Informational resources and reference documents			Physical Records and Google Drive

	maintained by the office			
Formal Agreements	Records of formal agreements entered into by the office with other parties		Admin Officer	Physical Records and Google Drive
Strategic Plans	Records describing the office's goals and planned courses of action		Office as a Whole	Physical Records and Google Drive

Answer:

- Certificates (personal and organizational awards, recognitions/appreciation)
- Inventory of External partners (NGOs, schools, LGUs, government agencies, community organizations)
- Monitoring and evaluation reports
- Staff records (contracts, evaluations)
- Accomplishment reports (narrative and presentations)
- Liquidation reports
- Request for payments
- Received copies of invitations and other formal correspondence
- Books, magazines, and other publications (e.g., modules, manuals, etc.)
- Copies of formal agreements
- Strategic plans

6. Which of these are the most sensitive or important?
Answer: Monitoring and evaluation reports, finance-related documents, copies of formal agreements, and strategic plans

7. Who owns or is responsible for each one?
Answer: Monitoring and evaluation reports (as an office), finance-related documents (usually the admin officer), copies of formal agreements (usually the admin officer), and strategic plans (as an office)

8. What would happen if each one were lost, leaked, changed by mistake, or unavailable for a few days?
Answer: Some of our operations would be at risk.

C. SYSTEMS AND TECHNOLOGY (Section II.c and III)

9. Where is each type of information stored (e.g., Google Drive, Google Forms, Excel files, email, Messenger, paper files, flash drives)?
Answer: Paper files and Google Drive folder (repository)

10. What computers, network, and email do you use? Are they office-owned or personal? Does anyone use personal devices or accounts for office work?
Answer: Institutional (office) email and personal email. We also use our personal devices for office work, especially when we are out of town.

11. Is there any antivirus, firewall, or other security software on the computers?
Answer: In terms of our computer desk in the office, we do not have security software. But on our personal devices, we do have.

D. ACCESS AND PASSWORDS (Section IV)

12. Who can access each system or folder? How is access given or removed when someone joins or leaves the office?
Answer: For our office (APC), only APC staff. We usually have a paper file with our credentials. But we also have it stored in our notes on our personal devices (e.g., notes, notepad). For our SDU email, everyone (APC, ACLG, and SDO staff only) has access to the SDU Gmail account. Access is given the same as the APC. If someone leaves, it is usually those who are still employed in the office who removes their access to the account.

13. Are accounts shared among staff? Do some staff have access to more than their job needs?
Answer: Yes, they are shared among staff. We only have access to SDU email. But we do not have access to other offices' emails. For instance, APC does not have access to ACLG's Gmail account. The same goes for ACLG.

14. Is there a password rule (e.g., length, how often it is changed)? Do you use two-step verification?
Answer: We do not have a password rule. Sometimes two-step verification appears, but sometimes it does not appear, especially if the device is saved in the account.

E. BACKUP AND DATA HANDLING (Section IV)

15. Do you back up your files? How often, where, and who does it?
Answer: We only store them in our repository GDrive folder. For physical paper files, we usually scan them first and then upload the scanned copy to the repository. It is usually managed by our Admin Officer, Program Officer, and Program Coordinator,

16. Has anyone ever tried restoring a backup to check if it works?
Answer: None so far.

17. How are files shared inside and outside the office (e.g., email, Messenger, links)?

Answer: Through email and shared links through Messenger.

18. How are paper documents stored and disposed of, and how long are records kept?
Answer: We store them in our paper binder in chronological order. They are kept for 10-15 years; then they are shredded, but it still depends on their significance (how important they are to be kept).

F. PHYSICAL SECURITY (Section IV)
18. Is the office locked? Who has keys or access?
Answer: Yes, it has locks. Each staff member has a spare key. The original key is kept by our admin officer.

19. Where are the computers and paper files kept? Can visitors see or reach them? Is there CCTV, a visitor log, or a locked cabinet?
Answer: Computers that are currently in use are kept on our computer desk. For spare computer sets (e.g., monitor, UPS, CPU), we have a large cabinet for this inside the office. Visitors can see them. We do not have CCTV, but we do have a visitor log and a locked cabinet.

G. POLICIES, TRAINING, AND INCIDENTS (Section IV)
20. Is there a written policy for data privacy, acceptable use, or incident handling? If yes, may we have a copy?
Answer: We usually have data privacy for our evaluations or surveys.

21. Have staff received training on data privacy or cybersecurity (e.g., the Data Privacy Act)?
Answer: None so far.

22. Has the office ever had a security incident, such as lost files, a hacked account, a message sent to the wrong person, or a lost device? What happened, and what was done?
Answer: We have had some lost files and lost devices in the past. Documents were misplaced or were mistaken for trash. That's why it is really important to have a scanned copy stored on our computer. For our experience with lost devices, it was mainly due to other offices borrowing and not returning them. Sometimes we just track them if they have logged onto our borrower's logbook, and if not, we report it to our admin officer and the Purchasing Custodian Office.

23. Who do staff report problems to?
Answer: The office head/unit director

H. WRAP-UP
24. What worries you most about how information is handled in your office?
Answer: If it is stored in their personal institutional account and in computer desk files and not in the office account or repository.

25. Is there anything we did not ask that we should know?

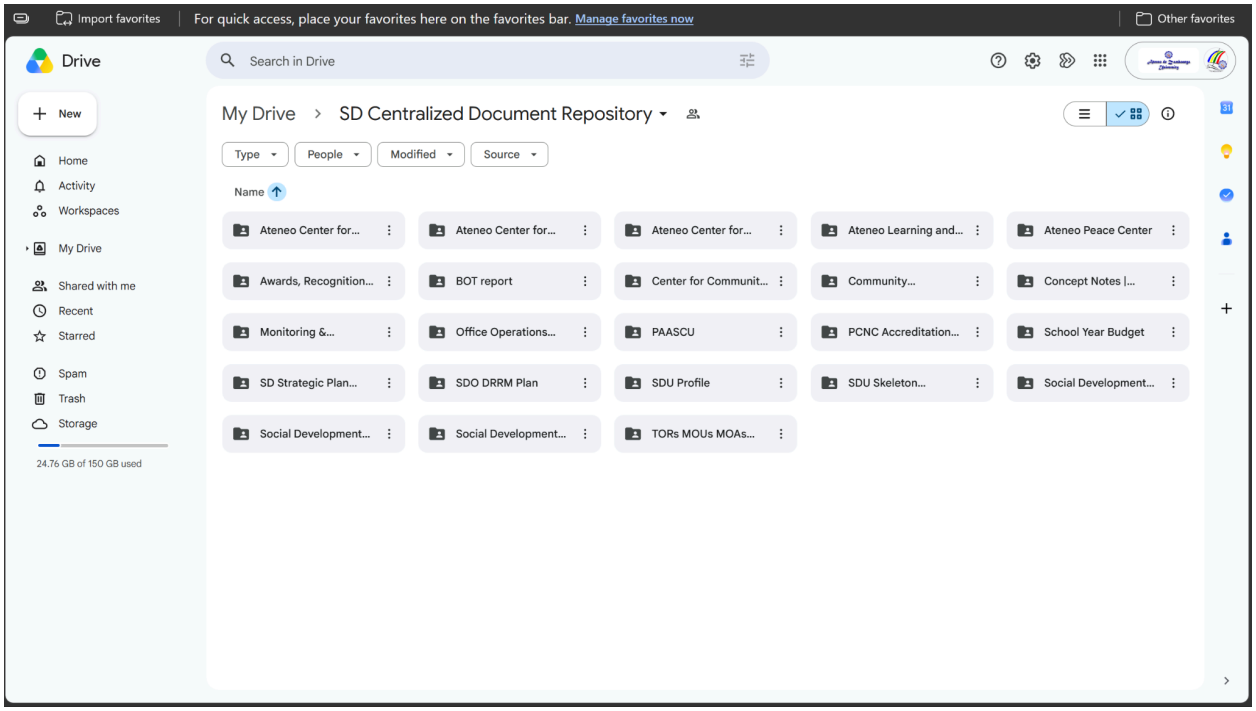
Answer: None so far.

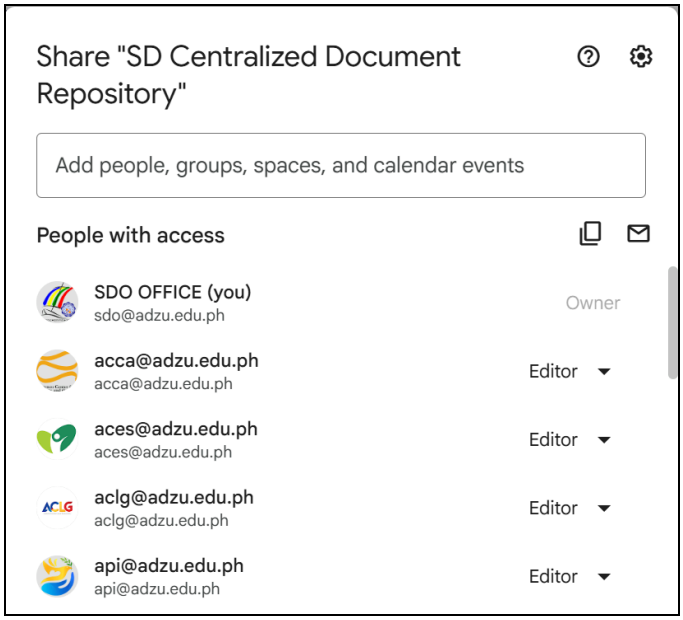
Optional Documents

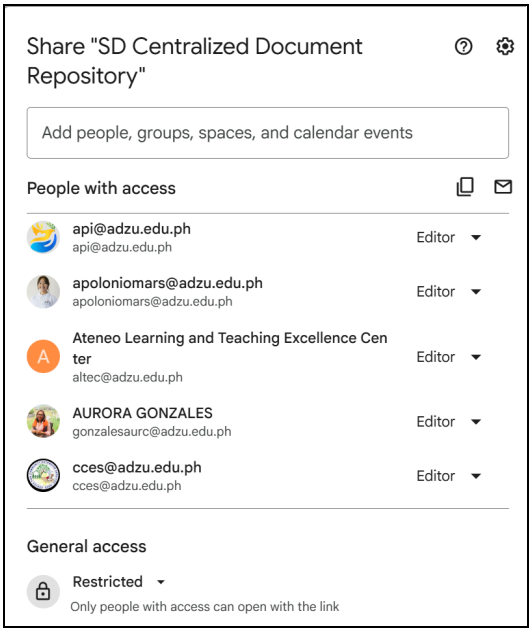
If available, it would help us po if you could share any of the following (with sensitive details removed): organizational chart, written policies or manuals, sample forms used by the office, and a screenshot of the folder structure or sharing settings of your main files.

Thank you very much po, Ma'am Mary! 🙏

Our SDU Centralized Repository:




Share "SD Centralized Document Repository"
Add people, groups, spaces, and calendar events
People with access
SDO OFFICE (you)
sdo@adzu.edu.ph
Owner
acca@adzu.edu.ph
acca@adzu.edu.ph
Editor
aces@adzu.edu.ph
aces@adzu.edu.ph
Editor
aclg@adzu.edu.ph
aclg@adzu.edu.ph
Editor
api@adzu.edu.ph
api@adzu.edu.ph
Editor


Share "SD Centralized Document Repository"
Add people, groups, spaces, and calendar events
People with access
api@adzu.edu.ph
api@adzu.edu.ph
Editor
apoloniomars@adzu.edu.ph
apoloniomars@adzu.edu.ph
Editor
Ateneo Learning and Teaching Excellence Center
altec@adzu.edu.ph
Editor
AURORA GONZALES
gonzalesaurc@adzu.edu.ph
Editor
cces@adzu.edu.ph
cces@adzu.edu.ph
Editor
General access
Restricted
Only people with access can open with the link

Information Security Audit Questionnaire

CIT.017 Information Assurance and Security – Final Project
Ateneo de Zamboanga University, College of Science and Information Technology, Computer Science Department
Prepared by: Shariff Isirani, Dorothy Ubag, Jean Caparas

Good day po, Ma'am Mary! Thank you for agreeing to be part of our project. This questionnaire will help us understand how your office handles its information, records, and tools. It is for class purposes only. We are not evaluating any person, only how information is handled. Please do not write actual passwords or personal data in your answers. You may skip any question you are not comfortable answering, and you may tell us if there is anything you would like us to leave out of the report. Short answers are fine. Please type your answers on the lines marked Answer:

Respondent Information

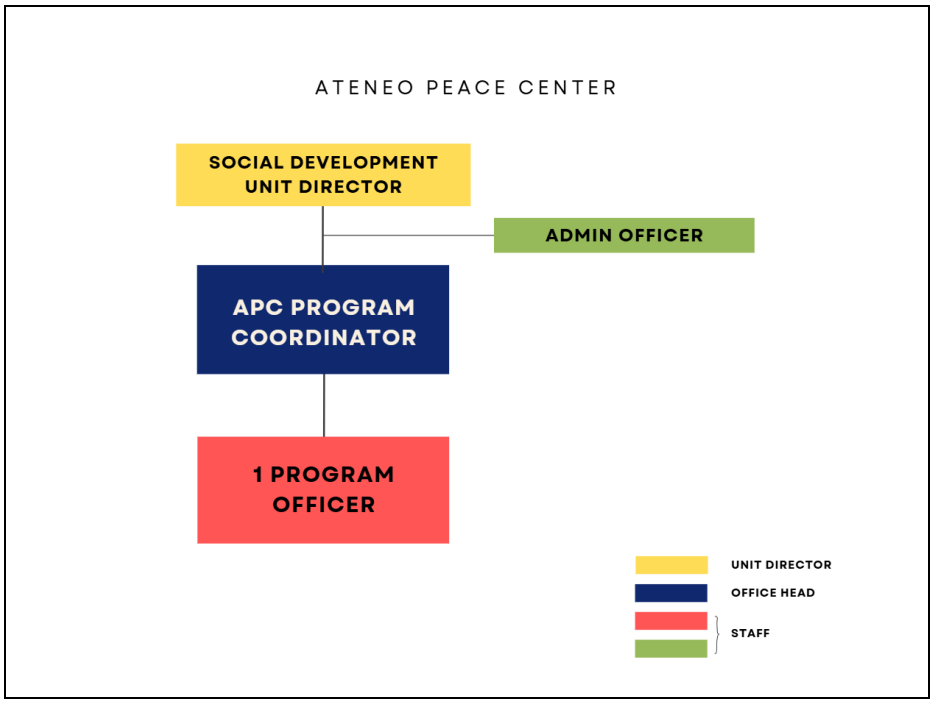
Name: Mary Elizabeth S Apolonio
Position: Program Coordinator
Office/Unit (official name): Ateneo Peace Center/Social Development Unit
Date answered: October 30, 2026

A. ORGANIZATION PROFILE (Section II)

1. What is the official name of your office, and what does it stand for?
Answer: APC or Ateneo Peace Center (formerly it was Ateneo Peace Institute)

2. Who is in your office and what are their roles? (An organizational chart is welcome if you have one.)
Answer: Current personnel:

- Mary Elizabeth Apolonio, Program Coordinator
- Fatima Raiza Ibrahim, Program Officer



**Note that our Admin Officer is the Admin/Support staff of the Social Development Office for now.*

3. What are the main functions or services of your office?
Answer: The Ateneo Peace Center empowers communities to build lasting peace through peace advocacy and communication, peace education, and research. It aims to promote transformative peace building mechanisms rooted from Ignatian spirituality, cultural sensitivity, and open dialogue.
What we do:

- Peace Advocacy: The aim of this program is to strengthen more effective peace building and conflict transformation mechanisms and improve peace, order, and harmony within the Ateneo community and across local communities.
- Peace Education: The program aims to equip individuals with knowledge, skills, and attitudes to build a culture of peace. This includes integrating peace values into existing curricula and co-curricular activities across Basic and Higher Education levels; designing and delivering educational programs on conflict resolution, nonviolence, and human rights; and training educators and community leaders.
- SALAAM-AdZU Organization: The SALAAM-AdZU Organization is the student volunteer arm of the Ateneo Peace Center (APC) of the Ateneo de Zamboanga University. This program empowers students to dive deeper into the culture of peace, providing a platform for meaningful engagement with the Ateneo community and offering hands-on experience in peace-related activities.

4. What are your most important business processes and the people involved based on each processes (e.g., training requests, partner coordination, reporting)? For each one, who is involved, what information is used, and what tool or system is used, and the specific

inputs/outputs

(EXAMPLE ONLY:) u can use the table po:

Major Business Process	*People Involved*	*Information Used*	*Information System Used*	*Inputs*	*Outputs*
Financial Documentation	Admin Officer, APC Personnel	Staff records, contracts, and evaluations	Google Drive, Email, Physical Records	Financial documents and payment requests	Maintained financial records

Answer:

B. INFORMATION ASSETS (Section III)
5. What kinds of information does your office keep (staff records, certificates, partner details, reports, evaluations, etc.)?

(Please add specific data included per assets and the personnel assigned / responsible owner)

u can answer here on the table po:

Information Asset	*Description*	*Data Included (SPECIFIC DATA HERE)*	*Responsible Owner*	*System*
Certificates and Recognitions	Records of awards, recognitions, and expressions of appreciation received by the office and its personnel			Physical Records and Google Drive
External Partner Inventory	Records of external organizations and institutions that collaborate or			Physical Records and Google Drive

	maintain partnerships with the office			
Monitoring and Evaluation Reports	Documents maintained for monitoring and evaluating the office's programs, projects, and activities		Office as a Whole	Physical Records and Google Drive
Staff Records	Records containing employment details and performance-related information of office personnel			Physical Records and Google Drive
Accomplishment Reports	Documents highlighting the outcomes and accomplishments of the office's activities		Office as a Whole	Physical Records and Google Drive
Financial Documents	Records of the office's financial transactions and related expenses		Admin Officer	Physical Records and Google Drive
Formal Correspondence	Official correspondence received by the office from individuals, institutions, and external organizations			Physical Records and Google Drive
Books and Publications	Informational resources and reference documents			Physical Records and Google Drive

	maintained by the office			
Formal Agreements	Records of formal agreements entered into by the office with other parties		Admin Officer	Physical Records and Google Drive
Strategic Plans	Records describing the office's goals and planned courses of action		Office as a Whole	Physical Records and Google Drive

Answer:

- Certificates (personal and organizational awards, recognitions/appreciation)
- Inventory of External partners (NGOs, schools, LGUs, government agencies, community organizations)
- Monitoring and evaluation reports
- Staff records (contracts, evaluations)
- Accomplishment reports (narrative and presentations)
- Liquidation reports
- Request for payments
- Received copies of invitations and other formal correspondence
- Books, magazines, and other publications (e.g., modules, manuals, etc.)
- Copies of formal agreements
- Strategic plans

6. Which of these are the most sensitive or important?
Answer: Monitoring and evaluation reports, finance-related documents, copies of formal agreements, and strategic plans

7. Who owns or is responsible for each one?
Answer: Monitoring and evaluation reports (as an office), finance-related documents (usually the admin officer), copies of formal agreements (usually the admin officer), and strategic plans (as an office)

8. What would happen if each one were lost, leaked, changed by mistake, or unavailable for a few days?
Answer: Some of our operations would be at risk.

C. SYSTEMS AND TECHNOLOGY (Section II.c and III)

9. Where is each type of information stored (e.g., Google Drive, Google Forms, Excel files, email, Messenger, paper files, flash drives)?
Answer: Paper files and Google Drive folder (repository)

10. What computers, network, and email do you use? Are they office-owned or personal? Does anyone use personal devices or accounts for office work?
Answer: Institutional (office) email and personal email. We also use our personal devices for office work, especially when we are out of town.

11. Is there any antivirus, firewall, or other security software on the computers?
Answer: In terms of our computer desk in the office, we do not have security software. But on our personal devices, we do have.

D. ACCESS AND PASSWORDS (Section IV)

12. Who can access each system or folder? How is access given or removed when someone joins or leaves the office?
Answer: For our office (APC), only APC staff. We usually have a paper file with our credentials. But we also have it stored in our notes on our personal devices (e.g., notes, notepad). For our SDU email, everyone (APC, ACLG, and SDO staff only) has access to the SDU Gmail account. Access is given the same as the APC. If someone leaves, it is usually those who are still employed in the office who removes their access to the account.

13. Are accounts shared among staff? Do some staff have access to more than their job needs?
Answer: Yes, they are shared among staff. We only have access to SDU email. But we do not have access to other offices' emails. For instance, APC does not have access to ACLG's Gmail account. The same goes for ACLG.

14. Is there a password rule (e.g., length, how often it is changed)? Do you use two-step verification?
Answer: We do not have a password rule. Sometimes two-step verification appears, but sometimes it does not appear, especially if the device is saved in the account.

E. BACKUP AND DATA HANDLING (Section IV)

15. Do you back up your files? How often, where, and who does it?
Answer: We only store them in our repository GDrive folder. For physical paper files, we usually scan them first and then upload the scanned copy to the repository. It is usually managed by our Admin Officer, Program Officer, and Program Coordinator,

16. Has anyone ever tried restoring a backup to check if it works?
Answer: None so far.

17. How are files shared inside and outside the office (e.g., email, Messenger, links)?
Answer: Through email and shared links through Messenger.

18. How are paper documents stored and disposed of, and how long are records kept?
Answer: We store them in our paper binder in chronological order. They are kept for 10-15 years; then they are shredded, but it still depends on their significance (how important they are to be kept).

F. PHYSICAL SECURITY (Section IV)

18. Is the office locked? Who has keys or access?
Answer: Yes, it has locks. Each staff member has a spare key. The original key is kept by our admin officer.

19. Where are the computers and paper files kept? Can visitors see or reach them? Is there CCTV, a visitor log, or a locked cabinet?
Answer: Computers that are currently in use are kept on our computer desk. For spare computer sets (e.g., monitor, UPS, CPU), we have a large cabinet for this inside the office. Visitors can see them. We do not have CCTV, but we do have a visitor log and a locked cabinet.

G. POLICIES, TRAINING, AND INCIDENTS (Section IV)
20. Is there a written policy for data privacy, acceptable use, or incident handling? If yes, may we have a copy?
Answer: We usually have data privacy for our evaluations or surveys.

21. Have staff received training on data privacy or cybersecurity (e.g., the Data Privacy Act)?
Answer: None so far.

22. Has the office ever had a security incident, such as lost files, a hacked account, a message sent to the wrong person, or a lost device? What happened, and what was done?
Answer: We have had some lost files and lost devices in the past. Documents were misplaced or were mistaken for trash. That's why it is really important to have a scanned copy stored on our computer. For our experience with lost devices, it was mainly due to other offices borrowing and not returning them. Sometimes we just track them if they have logged onto our borrower's logbook, and if not, we report it to our admin officer and the Purchasing Custodian Office.

23. Who do staff report problems to?
Answer: The office head/unit director

H. WRAP-UP
24. What worries you most about how information is handled in your office?
Answer: If it is stored in their personal institutional account and in computer desk files and not in the office account or repository.

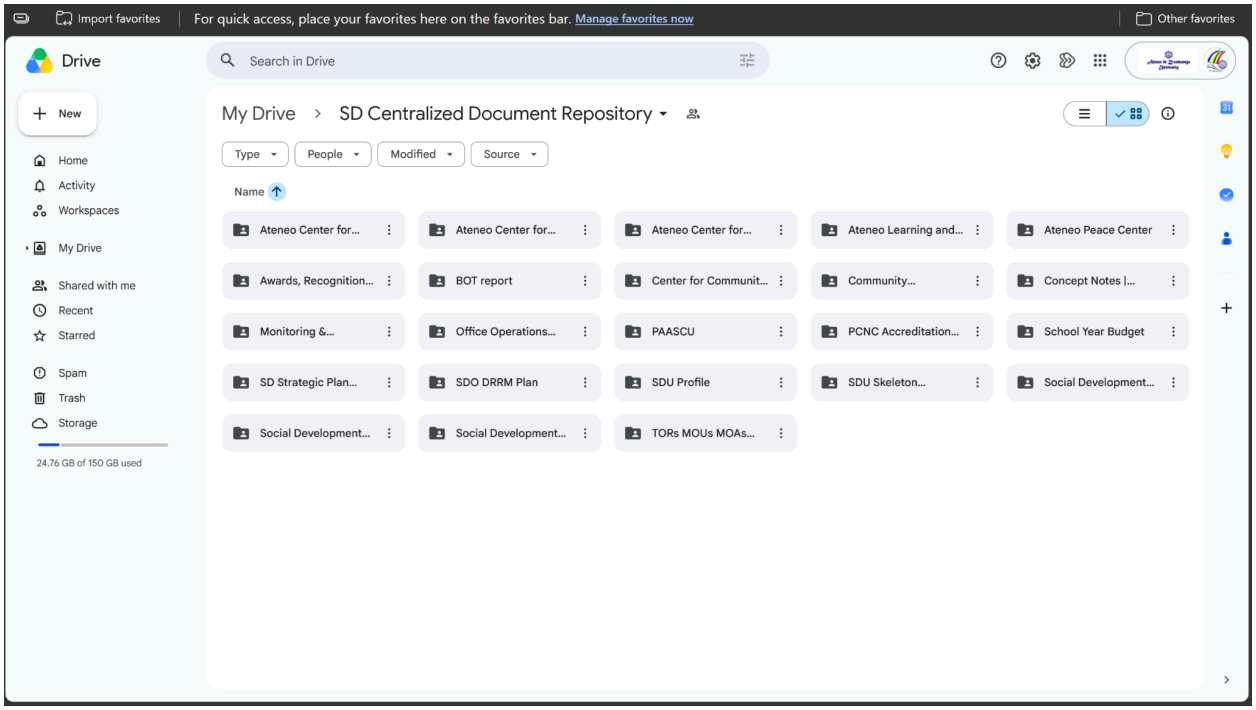
25. Is there anything we did not ask that we should know?
Answer: None so far.

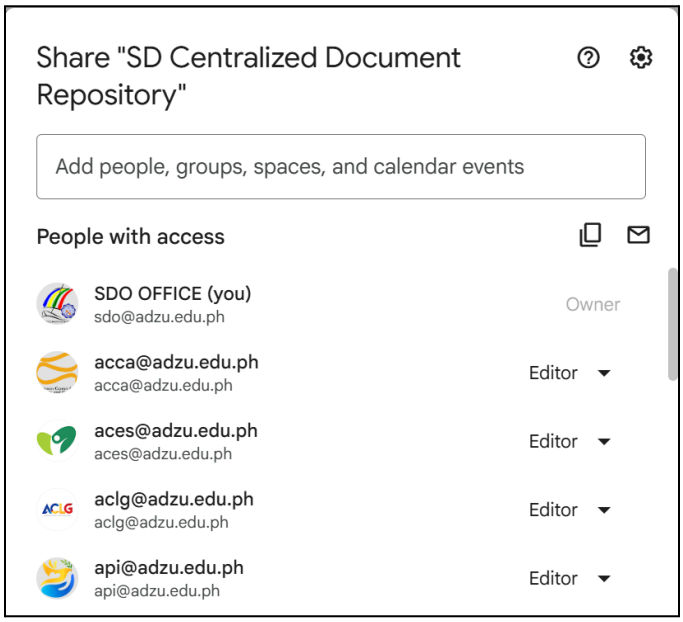
Optional Documents

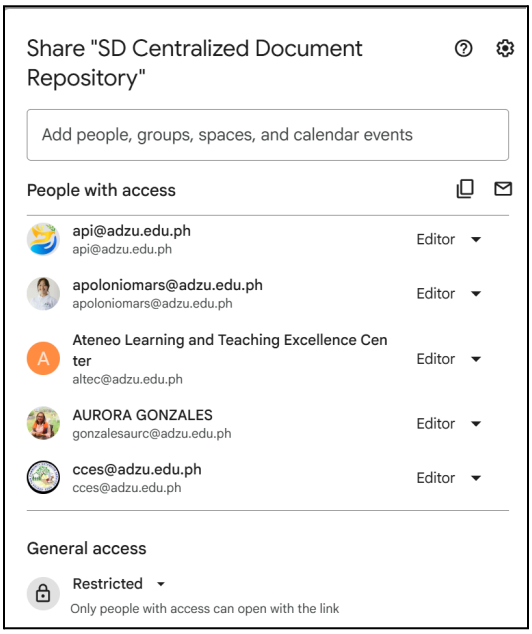
If available, it would help us po if you could share any of the following (with sensitive details removed): organizational chart, written policies or manuals, sample forms used by the office, and a screenshot of the folder structure or sharing settings of your main files.

Thank you very much po, Ma'am Mary! 🙏

Our SDU Centralized Repository:


Import favorites
For quick access, place your favorites here on the favorites bar. Manage favorites now
Other favorites
Drive
Search in Drive
New
Home
Activity
Workspaces
My Drive
Shared with me
Recent
Starred
Spam
Trash
Storage
24.76 GB of 150 GB used
My Drive
SD Centralized Document Repository
Type
People
Modified
Source
Name
Ateneo Center for...
Ateneo Center for...
Ateneo Center for...
Ateneo Learning and...
Ateneo Peace Center
Awards, Recognition...
BOT report
Center for Communit...
Community...
Concept Notes |...
Monitoring &...
Office Operations...
PAASCU
PCNC Accreditation...
School Year Budget
SD Strategic Plan...
SDO DRRM Plan
SDU Profile
SDU Skeleton...
Social Development...
Social Development...
Social Development...
TORs MOUs MOAs...


Share "SD Centralized Document Repository"
Add people, groups, spaces, and calendar events
People with access
SDO OFFICE (you)
sdo@adzu.edu.ph
Owner
acca@adzu.edu.ph
acca@adzu.edu.ph
Editor
aces@adzu.edu.ph
aces@adzu.edu.ph
Editor
aclg@adzu.edu.ph
aclg@adzu.edu.ph
Editor
api@adzu.edu.ph
api@adzu.edu.ph
Editor


Share "SD Centralized Document Repository"
Add people, groups, spaces, and calendar events
People with access
api@adzu.edu.ph
api@adzu.edu.ph
Editor
apoloniomars@adzu.edu.ph
apoloniomars@adzu.edu.ph
Editor
Ateneo Learning and Teaching Excellence Center
altec@adzu.edu.ph
Editor
AURORA GONZALES
gonzalesaurc@adzu.edu.ph
Editor
cces@adzu.edu.ph
cces@adzu.edu.ph
Editor
General access
Restricted
Only people with access can open with the link

COMPUTER RELATED

Statement	Yes	No
Antivirus or security software is installed		/
Office Wi-Fi is password-protected	/ (we only have the AdZU WiFi)	
Only office-owned devices are used for work		/
Printers/scanners are not left holding documents	/	
Screens lock automatically when left unattended		/
A firewall is enabled on applicable computers or network devices		/
Only authorized devices are used to access office information.	/	
Security software is regularly updated to detect new threats		/

STAFF QUESTIONS RELATED

Statement	Yes	No
Important accounts use two-step verification	/	
Personal data is not shared through personal email/chat	/	
Staff can only access what they need for their work	/	
Someone is responsible for IT and computers		/
Strong passwords are used for office accounts	/	
Data privacy or cybersecurity training is provided		/
Computers are locked when left unattended	/ (for some computers)	
Email recipients are verified before sending confidential files	/	
Confidential documents are secured after use	/	

DATA BACK UP AND RECOVERY RELATED

Statement	Yes	No
Important files are backed up regularly	/	
Backup copies are stored separately from the original files	/	
Backup copies are checked to ensure they can be restored		/
Backup files are protected from unauthorized access	/	
Important records are protected from accidental modification	/	
Responsibilities for managing backups are clearly assigned	/	
Backup storage has sufficient space for important files	/	
Backup procedures are documented		/
Recovery procedures are available in case of data loss		/
Access to backup files is limited to authorized personnel	/	

PHYSICAL SECURITY RELATED

Statement	Yes	No
Important paper records are kept in secure storage	/	
The office is locked when no authorized personnel are present	/	
Cabinets containing confidential documents are locked when not in use		/ (we lost the keys)
Visitors are monitored when entering restricted office areas	/	
Keys to restricted areas are provided only to authorized personnel	/	
CCTV cameras are installed in important areas where necessary	/ (but only outside of our office)	
Visitors cannot freely access computers or confidential records	/	
A visitor log is maintained when required	/	

Paper records are protected against fire, flooding, and other environmental hazards	/	
Restricted storage areas are accessible only to authorized personnel	/	

APC

INFORMATION SECURITY

AUDIT OF THE ATENEO PEACE CENTER

NOVEMBER 8, 2026

CAPARAS, JEAN JULIANA S.
ISIRANI, SHARIFF D.
UBAG, DOROTHY T.

BACHELOR OF SCIENCE IN
INFORMATION TECHNOLOGY - IV

TABLE OF CONTENTS

I. INTRODUCTION **5**
- a. Background of Audit 5
- b. Purpose of Information Security Audit 5
- c. Scope and Boundaries 2
- d. Audit Approach 2

II. ORGANIZATION PROFILE **5**
- a. Background of the Organization 5
- b. Business Process 6
- c. Information Systems Environment 7

III. INFORMATION ASSET INVENTORY **8**
- a. List of Information Assets 9
- b. Asset Classification 10

IV. EXISTING SECURITY CONTROLS **13**
- a. Technology 13
- b. Policy and Practices 15
- c. Human Factors 17
- d. Control Classification 18

V. Threat and Vulnerability Identification **19**
- a. Threat 19
- b. Vulnerability 20
- c. Asset-Threat-Vulnerability 22

VI. Risk Assessment **23**
- a. Risk Identification 24
- b. Likelihood Assessment 25
- c. Impact Assessment 26
- d. Risk Rating 27
- e. Risk Register 29

VII. Audit Findings **29**
- a. Summary of Findings 30
- b. Significant Findings 30
- c. Evidence supporting the findings 31
- d. Significance of the Findings 32
- e. Information Assets Affected 33
- f. Risks Created from the Findings 33
- g. Possible Impact if the Weaknesses Are Exploited 34

VIII. Recommended Security Improvements **36**
- a. Risk Treatment 36
- b. Recommended Controls 37
- c. Prioritization of Recommended Controls 40

References **44**

Appendix A **45**

Appendix B **46**

Appendix C **52**
Appendix D **55**

LIST OF FIGURES

Figure 1.1 4
Information Security Audit Questionnaire 4
Figure 1.2 4
Information Security Audit Checklist 4
Figure 2.1 5
Organizational Chart of the Ateneo Peace Center 5
Figure 2.2 8
Information Systems Environment of the Ateneo Peace Center 8

LIST OF TABLES

Table 1.1 6
Summary of Audit Activities 6
Table 2.1 10
Major Functions and Programs of the Ateneo Peace Center 10
Table 2.2 11
Major Business Processes and Information Requirements of the Ateneo Peace Center 11
Table 3.1 13
Identified Information Assets 13
Table 3.2 15
Rubric for Information Asset Classification 15
Table 3.3 16
Summary of Information Asset Classification 16
Table 4.1 18
Existing Technology Controls of the Ateneo Peace Center 18
Table 4.2 19
Existing Policies and Practices of the Ateneo Peace Center 19
Table 4.3 22
Classification of the Existing Controls 22
Table 5.1 23
Identified Threats to APC Information Assets 23
Table 5.2 25
Identified Vulnerabilities in the APC Environment 25
Table 5.3 26
Asset-Threat-Vulnerability Relationships 26
Table 6.1 28
Identified Risks 28
Table 6.3 29
Likelihood Ratings 29
Table 6.4 30
Impact Scale 30
Table 6.5 31
Impact Ratings 31
Table 6.6 31
Risk Assessment Matrix 31

Table 6.7 32
Risk Ratings 32
Table 6.8 33
Risk Register 33
Table 7.1 34
Summary of Audit Findings 34
Table 8.1 39
Risk Treatment for the Identified Risks 39
Table 8.2 41
Recommended Security Controls for the Ateneo Peace Center 41
Table 8.3 44
Prioritization of Recommended Controls 44

I. INTRODUCTION

This section presents the information security audit conducted for the Ateneo Peace Center (APC). It provides an overview of the office, explains the purpose and objectives of the audit, identifies its scope and boundaries, and describes the information gathering methods used in conducting the audit.

a. Background of Audit

The information security audit was conducted at the Ateneo Peace Center (APC), an office of Ateneo de Zamboanga University under the Social Development Unit (SDU). Formerly known as the Ateneo Peace Institute, the office works to build lasting peace in communities through peace advocacy and communication, peace education, and research. To carry out these programs, the office coordinates with external partners such as NGOs, schools, local government units, government agencies, and community organizations, and it also prepares program reports and handles financial documents such as liquidation reports and requests for payment.

Information plays an important role in supporting the office's daily operations. The office maintains various records, including certificates and recognitions, external partner records, monitoring and evaluation reports, staff records, accomplishment reports, liquidation reports, requests for payment, formal correspondence, publications, copies of formal agreements, and strategic plans. These records support the office in coordinating with partners, monitoring program results, processing financial transactions, documenting partnerships, and planning its activities. The records are stored in both physical files and a Google Drive repository. Staff also use institutional and personal email accounts, personal devices, and shared links through email and Messenger to access and exchange information.

Protecting these information assets is important to ensure the continuity of the office's operations and programs. Among the records considered most sensitive or important are monitoring and evaluation reports, financial documents, copies of formal agreements, and strategic plans. Losing, exposing, altering, or being unable to access these records could affect the office's activities and coordination with its partners. The office has also experienced incidents involving lost files and lost devices, as well as the loss of a key to a cabinet containing confidential documents, which further highlights the need for proper information security practices. Since some of the office's records contain personal information about staff and partners, they must be handled in accordance with the Data Privacy Act of 2012 (Republic Act No. 10173). Under Section 20 of the Act, organizations are required to

implement reasonable and appropriate security measures to protect personal information against unauthorized access, loss, destruction, alteration, and disclosure. Therefore, protecting the confidentiality, integrity, and availability of these information assets (Whitman & Mattord, 2022) is important to ensure that records remain secure, accurate, and accessible when needed. This also helps maintain the continuity of the office's operations and the trust of its partners.

b. Purpose of Information Security Audit

The purpose of this audit is to examine how the Ateneo Peace Center (APC) protects its information assets, identify areas that may need improvement, and recommend practical security measures suitable for the office's operations. This audit was conducted as part of the final project requirements for CIT.017 (Information Assurance and Security). It focuses on examining how information is handled and protected within the office. The results of the audit are intended to provide a baseline understanding of the office's current information security practices. The findings and recommendations may serve as a reference for identifying security gaps and determining which improvements should be prioritized to better protect the office's information assets and support its daily operations.

Specifically, this audit aims to:

1. Identify and describe the information assets maintained by the office, including where they are stored and who is responsible for them (Chapters II and III).
2. Document the existing security controls implemented by the office (Chapter IV).
3. Identify potential threats and vulnerabilities that could affect the office's information assets (Chapter V).
4. Assess the identified risks based on their likelihood and impact (Chapter VI).
5. Present the audit findings and recommend security improvements based on priority (Chapters VII and VIII).

C. Scope and Boundaries

This audit covers the Ateneo Peace Center (APC), including its staff and the Admin Officer who provides support to the office. In terms of physical location, the audit includes the APC office located on the Ateneo De Zamboanga University campus, particularly the computer desks, the cabinet for spare computer sets, the locked cabinet, and the binders used to store paper records. It also covers the digital locations where the office's records are stored, including the SDU Centralized Repository in Google Drive and the SDU Gmail account, as well as the personal devices used by staff for office-related work.

The information assets covered by the audit include the ten (10) categories identified in Chapter III (A-01 to A-10), both in physical form and in the Google Drive repository. It also includes the systems and tools used to manage and share these assets, such as office computers, personal devices, institutional and personal email accounts, and file-sharing platforms such as email and Messenger. Furthermore, the audit examines the office's practices concerning data backup, retention and disposal, access and password management, physical security, security policies, staff training, and incident handling.

The audit reflects the office's information security practices based on the information gathered through the questionnaire and audit checklist provided to the APC. The assessment is based on the information shared by the respondent as of October 30, 2026, which was the date the questionnaire was answered.

Several areas are excluded from the audit. Although other Social Development Unit (SDU) offices share the same email account and Google Drive repository, only the APC's use of these resources are included. The systems, records, and practices of the other offices are not examined. University-wide networks and servers, as well as the administration of Google accounts, are also outside of the scope of the audit. Additionally, the audit does not involve technical testing, such as vulnerability scanning or penetration testing. The actual contents of stored files were not inspected, and the respondent was instructed not to provide actual passwords or personal data. Lastly, the findings are based mainly on the responses of one respondent, the Program Coordinator. Therefore, the results only reflect the office's information security practices as described by the respondent.

d. Audit Approach

The information security audit was conducted through a series of activities, starting with planning and preparation, followed by information gathering, analysis, and documentation. Each of these activities involved specific tasks that contributed to the completion of the audit. Table 1.1 presents a summary of these activities, the tasks performed during each stage, and the corresponding chapters where the results are discussed.

Table 1.1

Summary of Audit Activities

Activity	*Description*	*Result in this documentation*
Planning and Preparation	Selected the office to be audited, coordinated with the APC Program Coordinator, and prepared the questionnaire and audit checklist.	Chapter I
Information Gathering	Provided the questionnaire and audit checklist to the APC Program Coordinator. The questionnaire was answered on October 30, 2026. Screenshots of the SDU Centralized Repository's folder structure and sharing settings were also provided as supporting materials.	Chapters II, III, and IV
Analysis	Identified and classified the information assets according to confidentiality, integrity, and availability. Reviewed the existing security controls, identified potential threats and vulnerabilities, and assessed risks based on their likelihood and impact.	Chapters III to VI
Documentation	Consolidated the audit findings and prepared recommendations for security improvements arranged based on priority.	Chapters VII and VIII

The activities presented in Table 1.1 provided a structured process for conducting the information security audit. The information gathered during the planning and preparation and information-gathering stages served as the basis for identifying the office's information assets and reviewing its existing security practices. These were then examined to identify potential threats and vulnerabilities and assess the risks that could affect the office's information assets.

The information-gathering methods used in this audit included the following:

- **Interview Questionnaire:** A set of questions covering the APC's office operations, business processes, information assets, information systems, and information security practices. The questionnaire was answered by Mary Elizabeth S. Apolonio, the APC Program Coordinator, on October 30, 2026. It was used to understand how the office handles its information, manages its records, and applies security practices in its daily operations.

- **Audit Checklist**: A security assessment instrument organized into different sections covering the office's existing security controls and practices. Each item required a Yes or No response from the APC Program Coordinator to determine whether a particular security measure or practice was implemented in the office.

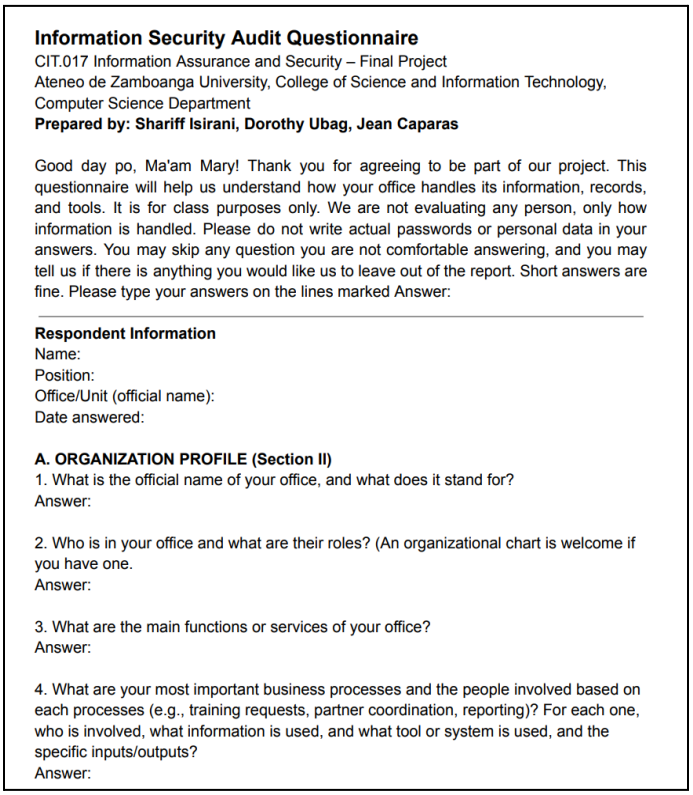
- **Document Review:** Supporting materials provided by the APC Program Coordinator, including screenshots of the APC organizational chart and SDU Centralized Repository's folder structure and sharing settings. These were reviewed to understand how the office organizes its digital records and manages access to shared files.

- **Follow-up:** A digital messaging platform was used to communicate with the APC Program Coordinator to clarify questionnaire responses and obtain additional information needed to complete the audit.

The following figures show the questionnaire and audit checklist used during the information-gathering stage. The complete versions of these instruments are provided in Appendices B and C, respectively.

Figure 1.1

Information Security Audit Questionnaire



Information Security Audit Questionnaire
CIT.017 Information Assurance and Security – Final Project
Ateneo de Zamboanga University, College of Science and Information Technology, Computer Science Department
Prepared by: Shariff Isirani, Dorothy Ubag, Jean Caparas

Good day po, Ma'am Mary! Thank you for agreeing to be part of our project. This questionnaire will help us understand how your office handles its information, records, and tools. It is for class purposes only. We are not evaluating any person, only how information is handled. Please do not write actual passwords or personal data in your answers. You may skip any question you are not comfortable answering, and you may tell us if there is anything you would like us to leave out of the report. Short answers are fine. Please type your answers on the lines marked Answer:

Respondent Information
Name:
Position:
Office/Unit (official name):
Date answered:

A. ORGANIZATION PROFILE (Section II)
1. What is the official name of your office, and what does it stand for?
Answer:

2. Who is in your office and what are their roles? (An organizational chart is welcome if you have one.
Answer:

3. What are the main functions or services of your office?
Answer:

4. What are your most important business processes and the people involved based on each processes (e.g., training requests, partner coordination, reporting)? For each one, who is involved, what information is used, and what tool or system is used, and the specific inputs/outputs?
Answer:

Figure 1.2

Information Security Audit Checklist

COMPUTER RELATED

Statement	Yes	No
Antivirus or security software is installed		
Office Wi-Fi is password-protected		
Only office-owned devices are used for work		
Printers/scanners are not left holding documents		
Screens lock automatically when left unattended		
A firewall is enabled on applicable computers or network devices		
Only authorized devices are used to access office information.		
Security software is regularly updated to detect new threats		

STAFF QUESTIONS RELATED

Statement	Yes	No
Important accounts use two-step verification		
Personal data is not shared through personal email/chat		
Staff can only access what they need for their work		
Someone is responsible for IT and computers		
Strong passwords are used for office accounts		
Data privacy or cybersecurity training is provided		
Computers are locked when left unattended		
Email recipients are verified before sending confidential files		
Confidential documents are secured after use		

II. ORGANIZATION PROFILE

This section presents the organizational profile of the Ateneo Peace Center (APC), covering its background, primary functions, and business processes. It also describes the information systems and technological resources utilized in managing records, coordinating with stakeholders, and supporting daily operations. These details provide an understanding of the office's operational environment and serve as a basis for examining how its information is managed, stored, and protected.

a. Background of the Organization

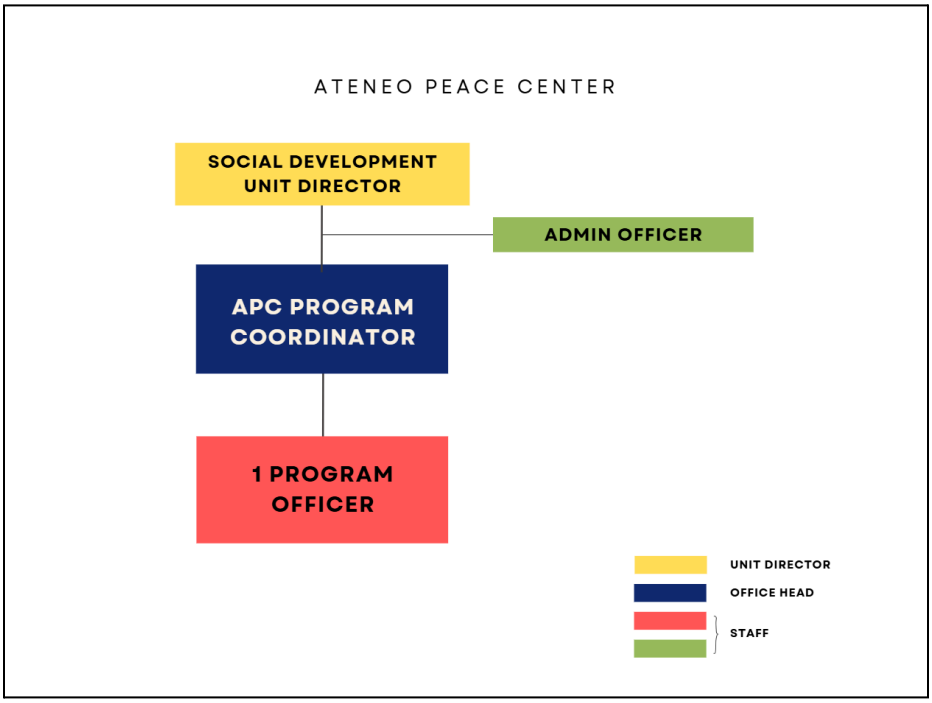
The Ateneo Peace Center (APC), formerly known as the Ateneo Peace Institute, is an institutional office of Ateneo de Zamboanga University (AdZU) under the Social Development Unit (SDU). It focuses on empowering communities to establish and sustain peace through initiatives in peace advocacy and communication, peace education, and research. Guided by Ignatian spirituality, cultural sensitivity, and open dialogue, the center promotes transformative approaches to peacebuilding and community development.

The Ateneo Peace Center is currently composed of two personnel who oversee and carry out its programs and daily activities. Mary Elizabeth S. Apolonio serves as the Program Coordinator, providing overall coordination and supervision of the center's initiatives, while Fatima Raiza Ibrahim serves as the Program Officer, supporting the

implementation and coordination of its programs and activities. In addition, the center receives administrative and support services from the Admin Officer of the Social Development Office. Figure 2.1 presents the organizational structure of APC and illustrates its personnel and administrative support.

Figure 2.1

Organizational Chart of the Ateneo Peace Center



The APC carries out its objectives through four main programs. Each program focuses on different aspects of peacebuilding, education, and community engagement, as presented in Table 2.1.

Table 2.1

Major Functions and Programs of the Ateneo Peace Center

Programs	*Description*
Peace Advocacy Program	Aims to strengthen peacebuilding efforts and conflict transformation mechanisms while fostering peace, order, and harmony within the Ateneo community and surrounding local communities.
Peace Education Program	Promotes a culture of peace by developing individuals' knowledge, skills, and attitudes through the integration of peace values into educational activities, programs on conflict resolution, nonviolence, and human rights, and training for

	educators and community leaders.
Muslim Affairs Program	Encourages intra and interreligious dialogue and mutual understanding among different religious groups while promoting respect and appreciation for diverse religious and cultural beliefs through education, research, and inclusive discussions.
SALAAM-AdZU Organization	Provides students with opportunities to learn about the culture of peace, engage in activities within the Ateneo community, and gain practical experience through participation in peace-related initiatives.

In carrying out its programs, the APC works with various external partners, including non-governmental organizations (NGOs), schools, local government units (LGUs), government agencies, and community organizations. The office also maintains an inventory of these partners as part of its organizational records.

b. Business Process

The Ateneo Peace Center (APC) carries out various administrative and operational tasks that require the proper handling and management of organizational information. These tasks include maintaining office records, preparing reports, monitoring and evaluating program activities, processing financial documents, managing personnel records, and organizing relevant information to support planning and decision-making. Through these activities, the office ensures that necessary information is documented, accessible to authorized personnel, and available to support its daily operations and program implementation.

The office's activities involve the handling of various information assets, including monitoring and evaluation reports, accomplishment reports, liquidation reports, requests for payment, formal agreements, correspondence, staff records, and strategic plans. To support these activities, the office uses digital platforms such as Google Drive, email accounts, and Messenger, along with physical paper records, to store, access, organize, manage, and share relevant information.

The following table presents the major business processes and activities identified based on the office's functions and the information assets indicated in the questionnaire responses. Since the respondent did not provide a detailed account of how each process is carried out, the activities are described based on the available information and should not be interpreted as verified step-by-step procedures.

Table 2.2

Major Business Processes and Information Requirements of the Ateneo Peace Center

Major Business Process	*People Involved*	*Information Used*	*Information System Used*	*Inputs*	*Outputs*
Monitoring and Evaluation	APC Personnel	Monitoring and evaluation reports	Google Drive, Physical	Monitoring and evaluation	Monitoring and evaluation

			Records	information	reports
Documentation and Accomplishment Reporting	APC Personnel	Accomplishment reports, certificates, and recognitions	Google Drive, Email, Physical Records	Activity documentation and supporting records	Narrative reports and presentation materials
Financial Documentation	Admin Officer, APC Personnel	Staff records, contracts, and evaluations	Google Drive, Email, Physical Records	Financial documents and payment requests	Maintained financial records
Administrative and Staff Records Management	APC Personnel, Admin Officer	Staff records, contracts, and evaluations	Google Drive, Physical Record	Staff-related documents	Maintained staff records
Partnership and Correspondence Records Management	APC Personnel	External partner inventory, formal agreements, invitations, and correspondence	Google Drive, Email, Messenger, Physical Records	Partner information and received correspondence	Organized partnership and communication records
Organizational Planning	APC Personnel	Strategic plans and related organizational documents	Google Drive, Physical Records	Organizational planning information	Strategic plans and documented organizational priorities

C. Information Systems Environment

This section describes the information systems environment of the Ateneo Peace Center (APC), covering the personnel, devices, applications, and storage resources used in its daily operations. The office relies on a combination of digital and physical resources to handle and maintain organizational information. Its personnel use office desktop computers and personal devices to access platforms such as Google Drive, institutional and personal email accounts, and Messenger. These tools support various office activities, including document storage, communication with individuals and external organizations, and file sharing for administrative and program-related purposes.

Figure 2.2

Information Systems Environment of the Ateneo Peace Center

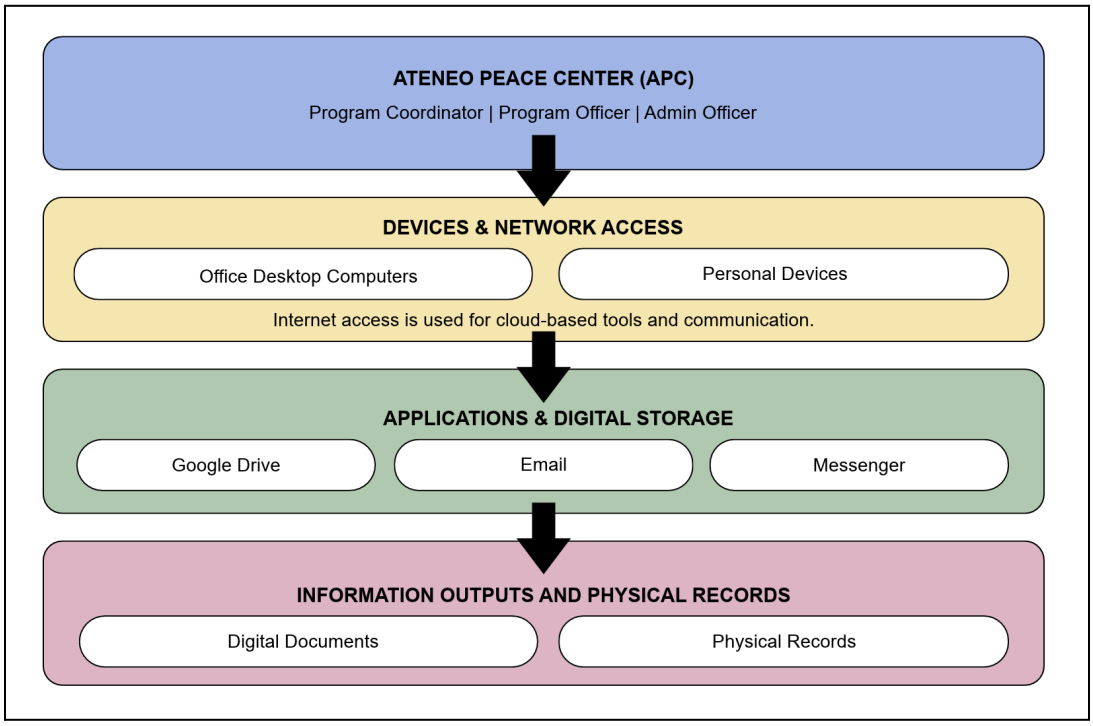


Figure 2.2 illustrates how the Ateneo Peace Center manages its organizational information through a combination of personnel, technological resources, and physical records. Office personnel use desktop computers and personal devices to access digital platforms, particularly Google Drive, which serves as the primary repository for office documents and scanned copies of physical records.

Furthermore, for communication and file exchange, the office also utilizes institutional and personal email accounts, as well as Messenger.

Aside from digital storage, important documents are kept in physical binders and arranged chronologically for easier reference and retrieval. These records are typically retained for 10 to 15 years, depending on their significance, before disposal through shredding. Through these resources, the office maintains and manages essential information, including monitoring and evaluation reports, financial documents, formal agreements, and strategic plans.

III. INFORMATION ASSET INVENTORY

This section presents the information assets managed and used by the organization to support its daily operations and administrative functions. It outlines the different categories of information handled by the office, including their description, data contents, and corresponding details. Recognizing these information assets allows the office to better understand the information it manages and determine the appropriate measures to ensure their security.

a. List of Information Assets

Based on the responses provided through the questionnaire, the APC office maintains various information assets that support its administrative and operational activities. These assets cover several areas, including administrative records such as certificates, staff records, and formal correspondence; financial documents such as liquidation reports and requests for payments; operational reports such as monitoring and evaluation reports and accomplishment reports; partnership-related records such as external partner information and formal agreements; and organizational reference materials such as books, magazines, modules, and manuals. The office also maintains strategic plans that guide its goals and planned activities. Additionally, the office maintains these information assets in physical paper files and a digital repository in Google Drive. Table 3.1 presents each identified asset, including its description, data contents, responsible owner, and application or storage location.

Table 3.1

Identified Information Assets

Asset ID	*Information Asset*	*Description*	*Data Included*	*Responsible Owner*	*System*
A-01	Certificates and Recognitions	Records of awards, recognitions, and expressions of appreciation received by the office and its personnel	Personal and organizational awards, recognitions, and appreciation	Program Coordinator and Program Officer	Physical Records and Google Drive
A-02	External Partner Inventory	Records of external organizations and institutions that collaborate or maintain partnerships with the office	NGOs, schools, LGUs, government agencies, and community organizations	Program Coordinator and Program Officer	Physical Records and Google Drive
A-03	Monitoring and Evaluation Reports	Documents maintained for monitoring and evaluating the office's programs, projects, and activities	Monitoring and evaluation information	Office as a Whole	Physical Records and Google Drive
A-04	Staff Records	Records containing employment details and performance-related information of	Employment contracts and staff evaluations	Admin Officer	Physical Records and Google Drive

Asset ID	*Information Asset*	*Description*	*Data Included*	*Responsible Owner*	*System*
		office personnel			
A-05	Accomplishment Reports	Documents highlighting the outcomes and accomplishments of the office's activities	Narrative reports and presentations	Office as a Whole	Physical Records and Google Drive
A-06	Financial Documents	Records of the office's financial transactions and related expenses	Liquidation reports and requests for payments	Admin Officer	Physical Records and Google Drive
A-07	Formal Correspondence	Official correspondence received by the office from individuals, institutions, and external organizations	Invitations and other formal correspondence received by the office	Program Coordinator and Program Officer	Physical Records and Google Drive
A-08	Books and Publications	Informational resources and reference documents maintained by the office	Books, magazines, modules, manuals, and other publications	Program Coordinator and Program Officer	Physical Records and Google Drive
A-09	Formal Agreements	Records of formal agreements entered into by the office with other parties	Copies of formal agreements	Admin Officer	Physical Records and Google Drive
A-10	Strategic Plans	Records describing the office's goals and planned courses of action	Records of Organizational strategic plans	Office as a Whole	Physical Records and Google Drive

b. Asset Classification

Each identified information asset (A-01 through A-10) is assessed and classified based on its security requirements to determine the appropriate controls needed to protect it. The assessment considers the three fundamental objectives of information security: Confidentiality, Integrity, and Availability (Whitman & Mattord, 2022). Following the guidelines of Federal Information Processing Standards Publication 199 (FIPS PUB 199), each information asset is assigned an impact level of Low, Moderate, or High. These levels are determined by the extent of potential harm that unauthorized disclosure, modification, or loss of access may cause to office operations, organizational assets, and individuals (National Institute of Standards and Technology [NIST], 2004).

The assessment covers information assets stored in both physical documents and digital files within Google Drive. Each asset's overall impact level is determined by considering the highest rating among the three security objectives. This provides a foundation for determining the appropriate security measures, access restrictions, and administrative procedures needed to safeguard the information and ensure uninterrupted office operations (NIST, 2004; Whitman & Mattord, 2022).

Table 3.2

Rubric for Information Asset Classification

Security Goal	*Low*	*Moderate*	*High*
Confidentiality (Unauthorized disclosure of information)	Minor disruption caused by the exposure of non-sensitive or publicly available information	Significant disruption caused by the exposure of internal office data, reports, or partner information	Severe impact on office operations and reputation resulting from the unauthorized disclosure of confidential documents
Integrity (Unauthorized modification or destruction of information)	Minor errors that can be easily corrected without delaying office operations	Significant errors that require manual cleanup and noticeably delay daily office tasks and reporting	Major damage to official records that affects their accuracy and validity, potentially resulting in audit or legal issues
Availability (Disruption of access to or use of information or an information system)	Minor operational impact, as the information can remain unavailable for several days without disrupting essential office activities	Temporary interruptions that noticeably slow down daily office operations or external communication	Severe system downtime that prevents the office from carrying out essential activities

Table 3.2 presents the classification criteria for the three security objectives, defining the Low, Moderate, and High impact levels used to assess the potential risks associated with each information asset.

For Confidentiality, the impact levels range from minor consequences resulting from the exposure of non-sensitive or publicly available information to serious operational and reputational damage caused by the

unauthorized disclosure of confidential records. For Integrity, the criteria focus on the possible effects of inaccurate, altered, or damaged information. These range from minor errors that require little correction to serious data corruption that affects the reliability of official records and may result in audit or legal concerns. Lastly, Availability measures the impact of interruptions in accessing information assets. These range from minor delays that do not significantly affect office operations to major disruptions that prevent the office from performing essential tasks and activities.

Overall, the assessment follows the security categorization methodology established by FIPS PUB 199 (NIST, 2004). Using the high-water mark principle, each asset's Overall Importance is determined by its highest impact rating across the three security objectives. This rating serves as the basis for identifying the minimum security controls required for each asset (NIST, 2004).

Table 3.3

Summary of Information Asset Classification

Asset ID	*Information Asset*	*Confidentiality*	*Integrity*	*Availability*	*Overall Importance*
A-01	Certificates and Recognitions	Low	Low	Low	Low
A-02	External Partner Inventory	Moderate	Moderate	Moderate	Moderate
A-03	Monitoring and Evaluation Reports	Moderate	High	Moderate	High
A-04	Staff Records	High	High	Moderate	High
A-05	Accomplishment Reports	Low	Moderate	Low	Moderate
A-06	Financial Documents	High	High	High	High
A-07	Formal Correspondence	Moderate	Moderate	Low	Moderate
A-08	Books and Publications	Low	Low	Low	Low
A-09	Formal Agreements	High	High	Moderate	High
A-10	Strategic Plans	High	High	Moderate	High

Table 3.3 presents the classification results of the Ateneo Peace Center (APC) information assets based on the security categorization methodology outlined in Federal Information Processing Standards Publication 199 (FIPS PUB 199) (NIST, 2004).

Table 3.3 presents the classification results of the Ateneo Peace Center (APC) information assets based on the security categorization methodology outlined in Federal Information Processing Standards Publication 199 (FIPS PUB 199) (NIST, 2004). To reflect the center's actual operational conditions, the assessment was based on the responses provided by the Program Coordinator through a questionnaire.

Information assets classified as High in overall importance include critical financial, legal, administrative, and evaluative records. Their compromise could result in serious operational disruptions or legal consequences. The Program Coordinator identified four information assets as highly sensitive based on the questionnaire responses. These include Financial Documents (A-06), Formal Agreements (A-09), Strategic Plans (A-10), and Monitoring and Evaluation Reports (A-03). Staff Records (A-04) was also placed under the High classification following the security assessment of its potential impact on the center. While identified as general office files in the questionnaire, personnel records include Personally Identifiable Information (PII), employment contracts, and performance evaluations that are subject to protection under the Data Privacy Act of 2012 (Republic Act No. 10173).

The other assets classified as High also require appropriate security measures due to their importance to the center's operations. Financial Documents (A-06) require protection across Confidentiality, Integrity, and Availability to maintain accurate financial records, support audit requirements, and prevent delays in payment processing and purchasing activities. Formal Agreements (A-09) and Strategic Plans (A-10) are essential in maintaining the center's legal commitments and guiding its institutional direction. Meanwhile, Monitoring and Evaluation Reports (A-03) require a high level of integrity protection, as inaccurate or corrupted evaluation data could affect research findings and weaken the center's credibility.

Information assets classified as Moderate in overall importance include the External Partner Inventory (A-02), Accomplishment Reports (A-05), and Received Formal Correspondence (A-07). These assets support the center's regular activities and administrative functions, although their compromise would not significantly affect its overall operations. The External Partner Inventory (A-02) received a Moderate rating across all three security objectives because the loss or exposure of partner contact information may affect communication and coordination but would not stop the center's main activities. Meanwhile, Accomplishment Reports (A-05) and Received Formal Correspondence (A-07) received Low to Moderate ratings for Confidentiality and Availability, as their temporary unavailability would have limited effects on daily operations. However, both were assigned a Moderate rating for Integrity to ensure the accuracy of records.

Information assets classified as Low in overall importance include Certificates and Recognitions (A-01) and Books and Publications (A-08). Since these materials are either publicly available or can be easily replaced, their unauthorized disclosure poses minimal confidentiality concerns. Similarly, their loss or temporary unavailability would have little effect on the center's daily operations.

Overall, the application of the FIPS PUB 199 high-water mark principle provides a consistent basis for assessing the risks associated with APC's information assets. The classification of the ten assets also helps establish security priorities and determine the appropriate protection measures based on their respective levels of importance.

IV. EXISTING SECURITY CONTROLS

This section presents the security controls currently in place at the Ateneo Peace Center (APC). The information is based on the questionnaire answered by the APC Program Coordinator, the completed audit checklist, and the screenshots provided showing the sharing settings of the SD Centralized Repository. A control refers to any technical, procedural, or physical measure used to protect an information asset (Whitman & Mattord, 2022). The identified controls are discussed under three categories: technology (hardware, software, and physical security), policies and practices, and human factors. They are also classified as preventive, detective, or corrective controls.

a. Technology

This subsection presents the existing technology-related security controls of the Ateneo Peace Center (APC), covering its hardware, software, and physical security. Table 4.1 summarizes the controls identified during the audit and the information assets they are intended to protect. The corresponding asset codes from Chapter III are included to show the relationship between each control and the assets it applies to. The succeeding sections provide a more detailed discussion of these controls.

Table 4.1

Existing Technology Controls of the Ateneo Peace Center

Security Control	*Category*	*Description and Evidence*	*Assets Protected*
Spare computer sets	Hardware	Spare computer sets (monitor, UPS, and CPU) are kept in a large cabinet inside the office.	Office computing equipment
Borrower's logbook for office devices	Hardware	Devices that other offices borrow are recorded in a borrower's logbook. Lost devices are traced through it, and unlogged devices are reported to the Admin Officer and the Purchasing Custodian Office	Office devices
Google Drive repository	Software	Digital copies of the office's records are kept in the SDU Centralized Repository owned by the SDO office account. General access is set to "Restricted," and only APC staff access the office's own files. Several unit and individual accounts hold Editor access to the main folder (screenshots).	A-01 to A-10 (digital copies)
Scanned Copies of paper records	Software	Paper files are scanned and the scanned copy is uploaded to the repository. A scanned copy is also kept on the office computer, which	A-01 to A-10 (paper copies)

Security Control	*Category*	*Description and Evidence*	*Assets Protected*
		helped the office after files were lost.	
Security software on personal devices	Software	Security software is installed on the personal devices used for work. The office computer desk has no antivirus or other security software.	A-01 to A-10 (digital copies opened on personal devices)
Two-step verification	Software	Two-step verification sometimes appears at log-in, but not when the device is already saved in the account.	A-01 to A-10 (email and repository accounts)
Office locks and key control	Physical	The office has locks. Each staff member has a spare key, and the original key is kept by the Admin Officer.	A-01 to A-10 (paper copies); office computers and equipment
Locked cabinet	Physical	The office has a locked cabinet.	Items kept in the locked cabinet
Visitor log	Physical	The office keeps a visitor log. It has no CCTV, and visitors can see the computers.	A-01 to A-10 (paper copies); office computers and equipment

As presented in Table 4.1, the hardware identified during the audit includes the computers kept on the computer desk, the personal devices used by staff for office-related work, and the spare computer sets, which include a UPS, monitor, and CPU. The spare computer sets provide the office with additional equipment that can be used when needed. However, the respondent did not specify whether the UPS also provides power protection for the computers currently in use. No other hardware-based security measures, such as a dedicated firewall device, were reported. The borrower's logbook is used to keep track of devices borrowed by other offices. This practice helps the office monitor the whereabouts of borrowed equipment, particularly since the office has previously experienced incidents involving devices that were borrowed and not returned.

Digital copies of the office's records are stored in the SDU centralized repository, a shared folder in Google Drive. The repository contains digital copies of the ten information asset categories identified in Chapter III (A-01 to A-10). Based on the provided screenshots, the main folder is owned by the SDO office account and shared with several unit and individual accounts, all of which have Editor access. Its general access setting is "Restricted," meaning that only accounts specifically granted permission can access it. According to the respondent, APC staff can access their own office's files. However, the screenshots only show the sharing settings of the main folder, so the permissions of individual subfolders, including the Ateneo Peace Center folder, could not be verified. This is particularly relevant to the information assets rated High for confidentiality in Chapter III: Staff Records (A-04), Financial Documents (A-06), Formal Agreements (A-09), and Strategic Plans (A-10). It also applies to the five assets rated High for integrity: A-03, A-04, A-06, A-09, and A-10. Since accounts with Editor access can modify files, reviewing the permissions of these assets is important to ensure that editing access is given only to those who need it.

Paper records are scanned, and their digital copies are uploaded to the repository. The respondent also mentioned that scanned copies are kept on the office computer and have been used as references when files were misplaced. In terms of account access, the institutional SDU Gmail accounts are shared among staff within their respective offices. However, APC staff cannot access the Gmail accounts of other offices, such as ACLG. Staff also use their personal email accounts for office-related work. Two-step verification may appear during login, but it is not required when a device has already been saved in the account. Regarding device protection, security software is installed on the personal devices used for office-related work, while the office computers do not have antivirus or other security software installed. Files are also shared through email and links sent via Messenger, and the respondent did not report any additional security measures applied to files shared through these channels.

Physical security measures are used to protect the office's paper records, equipment, and other physical assets. The office uses locks to restrict access, with each staff member keeping a spare key while the original key is held by the Admin Officer. It also has a locked cabinet for storing records and equipment, as well as a visitor log for recording individuals who enter the office. However, the office does not have CCTV cameras, and visitors can see the computers inside the office. These measures provide basic ways of controlling physical access to the office and its contents. Their effectiveness also depends on the proper handling and safekeeping of the keys.

b. Policy and Practices

This subsection discusses the policies and practices that guide how the staff protect the information assets. Based on the information provided by the respondent, the only written policy mentioned was a data privacy statement used for evaluations and surveys. The practices described here are therefore mostly informal and depend on the habits of the staff. Table 4.2 summarizes the practices identified in each of the eight areas and presents and evaluates it using the same scale as Table 4.1.

Table 4.2

Existing Policies and Practices of the Ateneo Peace Center

Area	*Practice Observed*
Password policy	No password rule; credentials kept in a paper file and in notes on personal devices.
Access control procedure	Staff only access; remaining staff remove access when someone leaves; shared accounts; no written procedure.
Backup procedure	Files only stored in the repository; paper files scanned and uploaded; copy also kept on the office computer; no restore test.
Data handling procedure	Files shared by email and Messenger; paper kept 10 to 15 years then shredded; data privacy statement for evaluation and surveys.
Incident response procedures	No written procedure; scanned copies and borrower's logbook used; problems reported to the office head or unit director.
Acceptable-use policies	No written policy; staff use personal devices and email for office work.

Area	*Practice Observed*
Physical security procedures	Key arrangement, visitor log, locked cabinet, and borrower's logbook; no cctv.
Employee security awareness practices	No training; problems reported to the office head or unit director.

The practices summarized in Table 4.2 show that the Ateneo Peace Center (APC) relies mainly on informal arrangements in handling and protecting its information assets. Although the office follows certain practices for managing access, storing records, and responding to incidents, most of these practices are not supported by written policies or established procedures. The following discussion explains how these practices are currently carried out.

In terms of password management, the office does not have a formal password policy or established requirements for creating and maintaining passwords, as confirmed by the respondent. Login credentials are kept in a paper file and in notes on personal devices. This means that the handling of passwords depends mainly on the practices followed by the staff rather than on documented guidelines. Without established requirements, there may be differences in how staff create, store, and protect their login credentials.

Access to the office's information assets is also managed through informal arrangements. According to the respondent, access to APC's files and accounts is limited to APC staff. When a staff member leaves the office, the remaining staff remove that person's access. The institutional SDU Gmail account is shared among APC, ACLG, and SDO staff. However, the respondent explained that each office can access only its respective office email and cannot open the email accounts of the other offices. Although these practices help manage who can access the office's information, no written access control procedure was identified during the audit. As a result, access management mainly depends on the staff carrying out these practices when changes in office personnel occur.

For backup and file recovery, the respondent said that the office only stores its files in the repository folder. Paper records are scanned and uploaded to the repository by the Admin Officer, Program Officer, and Program Coordinator. The respondent also mentioned that scanned copies are kept on the office computer. These digital copies can serve as references when physical documents are misplaced. However, the office has not tested whether its stored files can be successfully restored from a backup. Therefore, the ability to recover these files in case of data loss has not been verified. This is particularly important for Financial Documents (A-06), which Chapter III identifies as the only information asset with a High availability rating.

The office also follows certain practices in handling, sharing, storing, and disposing of its records. Digital files are shared through email and links sent through Messenger. For physical records, documents are kept in binders and arranged chronologically. According to the respondent, these records are retained for 10 to 15 years before being shredded, depending on their importance. Responsibility for handling important records is also assigned within the office. Monitoring and evaluation reports and strategic plans are handled by the office as a whole, while finance-related documents and copies of formal agreements are usually managed by the Admin Officer. The only written policy mentioned was a data privacy statement used for evaluations and surveys. These practices help organize the office's records and identify who is responsible for handling them.

Regarding acceptable use, no formal acceptable-use policy was identified to provide specific guidelines for using personal devices and personal email accounts for office-related work, even though staff use these resources when performing their work. Furthermore, regarding incident handling, the office does not have a written incident response procedure. The respondent reported previous incidents involving misplaced files and lost devices. Some

documents were misplaced or mistaken for trash, while devices were mainly lost after being borrowed by other offices and not returned. When paper documents are misplaced, the office uses their scanned copies as references. For missing devices, the borrower's logbook is checked to help trace the equipment. If the device was not recorded in the logbook, the incident is reported to the Admin Officer and the Purchasing Custodian Office. Staff also report problems to the office head or unit director. These actions show that the office has ways of responding to certain incidents, but since the steps are not documented in a formal procedure, incident handling relies on the staff's knowledge of whom to inform and what actions to take.

The office also follows basic physical security practices to protect its workplace, equipment, and paper records. These include using keys and locks to restrict access, keeping a locked cabinet, and maintaining a visitor log to record individuals entering the office. What is kept inside the locked cabinet was not specified. Each staff member keeps a spare key, while the original key is held by the Admin Officer. The borrower's logbook is also used to monitor devices borrowed by other offices. However, the office does not have CCTV cameras, and visitors can see the computers inside the office. Although these practices provide some measures for managing physical access and tracking equipment, no written physical security procedure was identified. The proper handling and safekeeping of keys and the consistent recording of borrowed equipment remain important in maintaining these measures.

Lastly, the respondent reported that APC staff had not received training such as on data privacy or cybersecurity. The only related practice mentioned was reporting problems to the office head or unit director. No other formal security awareness activities or documented guidelines for educating staff about information security were reported. This indicates that staff have limited formal guidance on recognizing and handling possible security risks involving the office's information assets.

Overall, this shows that APC has several existing practices for protecting its information assets, particularly in managing access, organizing records, tracking borrowed equipment, and responding to reported incidents. However, many of these practices rely on informal arrangements rather than documented policies and procedures. The lack of formal guidelines for password management, access control, backup and recovery, acceptable use, incident response, and security awareness may make it difficult to ensure that these practices are consistently followed. These areas should therefore be considered in identifying the threats, vulnerabilities, and risks discussed in the succeeding chapters.

C. Human Factors

This subsection considers how staff knowledge, awareness, and practices relate to the information security controls discussed earlier. The Ateneo Peace Center (APC) has two staff members, the Program Coordinator and the Program Officer, who are supported by an Admin Officer shared with the Social Development Office. These individuals are involved in handling the office's daily operations.

When asked about information security training, the respondent answered, "None so far" (M.E. Apolonio, personal communication, October 30, 2026). This indicates that APC staff have not yet received training on data privacy or cybersecurity, including the Data Privacy Act of 2012. However, the respondent recognizes that losing, leaking, altering, or being unable to access the office's records could affect its operations. Previous incidents involving misplaced files also led the office to keep scanned copies of paper records as references. The respondent also expressed concern that some information may be stored in personal accounts or on computer desks instead of the institutional account or designated repository.

Some practices reflect a conscious effort to protect the information. Responsibility for the key records is assigned, the original key is kept by the Admin Officer, and problems are reported to the office head or unit director. These practices depend on the discipline of individuals, since no policy defines them, and they may change if a staff member leaves or is replaced. The lack of training appears to indicate that the office has not yet had a formal way to share security practices, and it does not suggest a lack of care on the part of the staff.

d. Control Classification

The identified controls were classified based on their type and function. Their type describes the nature of the control, such as technology (hardware or software), physical, or policy and practice. Meanwhile, their function describes the purpose it serves. Preventive controls help stop incidents from happening, detective controls help identify incidents, and corrective controls help reduce their effects or restore normal operations. The classification of the 17 identified controls is presented in Table 4.3.

Table 4.3

Classification of the Existing Controls

Security Control	*Type*	*Function*
Spare computer sets	Technology: Hardware	Corrective
Borrower's logbook for office devices	Technology: Hardware	Detective
Google Drive repository	Technology: Software	Preventive
Scanned copies of paper records	Technology: Software	Corrective
Security software on personal devices	Technology: Software	Preventive
Two-step verification	Technology: Software	Preventive
Office locks and key control	Physical	Preventive
Locked cabinet	Physical	Preventive
Visitor log	Physical	Detective
Password practices	Policy and Practice	Preseventive
Access control practices	Policy and Practice	Preventive
Backup practices	Policy and Practice	Corrective
Data handling practices	Policy and Practice	Preventive
Incident response practices	Policy and Practice	Corrective
Acceptable-use practices	Policy and Practice	Preventive
Physical security practices	Policy and Practice	Preventive/Detective

Security Control	*Type*	*Function*
Security awareness practices	Policy and Practice	Preventive

As shown in Table 4.3, most of the identified controls serve a preventive function. Ten are classified as preventive only, while physical security practices serve both preventive and detective functions. Two controls are classified as detective: the borrower's logbook and the visitor log. The remaining four are corrective controls: the spare computer sets, scanned copies, backup practice, and incident response practice.

V. Threat and Vulnerability Identification

This section identifies the threats that could harm the information assets of the Ateneo Peace Center (APC) and the vulnerabilities that would allow those threats to succeed. Threats were categorized following the classification of Whitman and Mattord (2022), and the identification process followed the guidance on threat sources and predisposing conditions in NIST Special Publication 800-30 (Joint Task Force Transformation Initiative, 2012) and ISO/IEC 27005 (International Organization for Standardization & International Electrotechnical Commission [ISO/IEC], 2022). The evidence comes from the interview questionnaire answered by the APC Program Coordinator on October 30, 2026 (M. E. Apolonio, personal communication, October 30, 2026), the observation checklist, and a screenshot of the sharing settings of the SDU Centralized Repository. Questionnaire items are cited as Q1 to Q25.

a. Threat

To identify the threats, the group went through each asset in Chapter III together with the interview answers and the observation checklist, and asked what could realistically go wrong given how the office stores and handles that asset. Each threat is given an ID, a category from the classification of Whitman and Mattord (2022), the assets it could affect, and a short description of its possible effect.

Both the paper records and the Google Drive repository are covered, so the threats come from digital, physical, human, and environmental sources. Table 5.1 lists the threats that could affect the ten information assets identified in Chapter III (A-01 to A-10). Each threat is assigned a category, the assets it could affect, and a description of its possible effect on the office.

Table 5.1

Identified Threats to APC Information Assets

Threat ID	*Threat*	*Threat Category*	*Affected Assets*	*Possible Effect*
T-01	Phishing or credential theft	Software attacks	A-01 to A-10 (Google Drive, SDU Gmail)	Attacker gains access to office accounts and files

Threat ID	*Threat*	*Threat Category*	*Affected Assets*	*Possible Effect*
T-02	Unauthorized access to the shared repository or shared accounts by internal or external users	Espionage or trespass	A-03, A-04, A-06, A-09, A-10	Viewing, copying, or changing sensitive records
T-03	Unauthorized physical access or theft of paper records, keys, and written credentials	Theft; espionage or trespass	A-04, A-06, A-09; credential paper file	Data disclosure and account takeover
T-04	Loss or theft of devices	Theft	Files on devices; logged-in accounts	Exposure of saved sessions, notes, and local files
T-05	Accidental disclosure through wrong recipients or personal channels	Human error or failure	A-02, A-04, A-06, A-07, A-09	Confidential files reach unintended people
T-06	Accidental loss, deletion, or misplacement of files	Human error or failure	A-01 to A-10	Records cannot be found or recovered
T-07	Malware infection on office computers	Software attacks	Files on office computers and synced Drive	Data corruption or theft; computer downtime
T-08	Hardware failure of office computers or storage	Technical hardware failures	Files saved only on office computers	Loss of locally stored files
T-09	Fire, flood, or other environmental damage	Forces of nature	Paper originals (A-01 to A-10)	Permanent loss of paper records
T-10	Loss of access to Google accounts or Drive (lockout, compromise, or service outage)	Deviations in quality of service	A-01 to A-10 (digital copies)	Work stops until access is restored

As shown in Table 5.1, the threats cover digital, physical, human, and environmental sources. Most of them (T-01, T-02, T-04, T-06, and T-10) depend on how the Google Drive repository and shared accounts are used, which fits the office's practice of keeping both paper files and one Google Drive repository (Q9, Q15). The remaining threats relate to the office's physical records and equipment.

The threats fall into four groups. Threats T-01, T-02, and T-10 target the shared Google accounts and the repository, where all ten assets are kept in digital form. Threats T-03, T-04, and T-09 concern the physical side, such as paper binders, keys, written credentials, and devices. Threats T-05 and T-06 come from human error, which is likely to occur here because the office has already experienced misplaced files and unreturned devices (Q22). Threats T-07 and T-08 are technical and mainly affect files kept on the office computers.

b. Vulnerability

Vulnerabilities are weaknesses in the office's controls, practices, or environment that a threat can take advantage of. Table 5.2 lists the vulnerabilities found, the systems or assets they affect, and the evidence used to identify them. The vulnerabilities were identified by comparing the office's actual practices, as described in the interview and the checklist, against common good practice in areas such as password management, access control, backup, awareness training, and physical protection. Table 5.2 gives each vulnerability an ID, names the system it affects, and states the basis for identifying it, usually the questionnaire item where the office described the practice.

Table 5.2

Identified Vulnerabilities in the APC Environment

Vulnerability ID	*Vulnerability*	*Affected System*	*Description and Basis*
V-01	Credentials stored insecurely	Office accounts	Credentials are kept in a paper file and in notes apps on personal devices (Q12)
V-02	Shared accounts	SDU Gmail account	One SDU account is used by APC, ACLG, and SDO staff, so actions cannot be traced to one person (Q12, Q13)
V-03	No password policy	All office accounts	The office has no password rule on length or changing (Q14)
V-04	Inconsistent two-step verification	Google accounts	Two-step verification sometimes does not appear, especially on devices already saved in the account (Q14)
V-05	No security software on office computers	Office desktop computers	The computer desk has no security software; only personal devices have (Q11)
V-06	Office data on personal devices, personal email, and desktop files	Personal devices; personal and institutional email	Staff use personal devices and personal email for office work, and some files are kept on computers instead of the repository (Q10, Q24)
V-07	Informal and broad access management	Google Drive repository	Access removal is done informally by remaining staff (Q12). The repository sharing screenshot shows many office accounts with Editor access (general access is Restricted)

Vulnerability ID	*Vulnerability*	*Affected System*	*Description and Basis*
V-08	No independent backup and no restore test	Google Drive repository	The repository is the only digital storage; no backup test has been done (Q15, Q16)
V-09	No written security policies or incident procedures	Office-wide	A written policy exists only for data privacy in evaluations and surveys (Q20); incidents are handled informally (Q22)
V-10	No security awareness training	Staff	No staff has received data privacy or cybersecurity training (Q21)
V-11	Weak physical protection and key control	Office premises; cabinets; devices	No CCTV inside the office, visitors can see the computers, each staff keeps a spare key, the cabinet keys were lost (checklist note), and borrowed devices were not returned (Q18 and Q19 in Section F, and Q22)
V-12	Limited protection of paper records	Paper binders	Paper records were misplaced or mistaken for trash (Q22); no fire or flood protection was reported (verify with checklist)

Table 5.2 shows that most weaknesses are about management and practice, not technology: account handling (V-01 to V-04, V-07), data handling (V-06, V-08), and missing policies and training (V-09, V-10). This matches the office's own concern that information may be stored in personal accounts and desktop files instead of the repository (Q24). The physical weaknesses (V-11, V-12) are made more serious by documented past losses of files and devices (Q22). Each vulnerability makes at least one threat in Table 5.1 easier to carry out. For example, credentials kept on paper and in notes (V-01), shared accounts (V-02), and the lack of a password policy (V-03) all make phishing and unauthorized access (T-01, T-02) more likely to succeed, while the lack of an independent backup (V-08) means that accidental deletion or loss of access (T-06, T-10) could become permanent. The vulnerabilities are therefore the link between the threats in Table 5.1 and the risks assessed in Chapter VI.

C. Asset-Threat-Vulnerability

Table 5.3 links each asset to the vulnerability that a threat could exploit and the resulting consequence based on the security goals of confidentiality, integrity, and availability (CIA). This linking is the basis of the risk identification in Chapter VI. Using the threats and vulnerabilities above, the group asked which weakness a given threat could use against which asset, and which security goal would be harmed. Each row of the table therefore reads as a short scenario: the asset at stake, the weakness that is present, the threat that could use it, and the result for confidentiality, integrity, or availability.

Table 5.3

Asset-Threat-Vulnerability Relationships

Asset	*Vulnerability*	*Threat*	*Possible Consequences*
Financial Documents (A-06), Formal Agreements (A-09)	V-01 Credentials stored insecurely	T-03 Physical access or theft	Compromises confidentiality; enables account takeover
All digital assets (A-01 to A-10)	V-03 No password policy; V-04 Inconsistent two-step verification	T-01 Phishing or credential theft	Compromises confidentiality and integrity
Strategic Plans (A-10), Monitoring and Evaluation Reports (A-03)	V-02 Shared accounts; V-07 Broad access	T-02 Unauthorized access	Compromises confidentiality; changes cannot be traced to a person
Staff Records (A-04)	V-07 Broad access	T-02 Unauthorized access	Compromises confidentiality of personal data
Files on devices and logged-in sessions	V-04, V-05, V-11	T-04 Loss or theft of devices	Compromises confidentiality; possible loss of availability
Partner Inventory (A-02), Formal Correspondence (A-07)	V-06 Data on personal channels; V-10 No training	T-05 Accidental disclosure	Compromises confidentiality
Paper records (A-01 to A-10)	V-12 Limited protection of paper records	T-06 Loss or misplacement	Compromises availability
Files on office computers	V-05 No security software	T-07 Malware	Compromises integrity and availability
Files saved only on computers	V-06; V-08 No independent backup	T-08 Hardware failure	Compromises availability
Paper originals	V-12	T-09 Fire, flood, environmental damage	Compromises availability
Drive repository (A-01 to A-10)	V-08 No backup or restore test; V-09 No incident procedure	T-10 Loss of account access; T-06 Deletion	Compromises availability and integrity

Table 5.3 shows that the weaknesses on account access (V-01 to V-04, V-07) affect confidentiality of the most sensitive assets (finance, agreements, strategic plans, and staff records), while the weaknesses on backup, physical protection, and record handling affect availability. Reading across Table 5.3, the scenarios on account access (V-01 to V-04, V-07) mostly harm confidentiality, because they involve the finance documents, formal agreements, strategic plans, and staff records. The shared account (V-02) also harms integrity indirectly, since a change to a file cannot be traced to one person. The scenarios on backup, record handling, and physical protection (V-08, V-12) mostly harm availability. These scenarios are the starting point for the risk identification that follows.

VI. Risk Assessment

This section estimates the risks arising from the threats and vulnerabilities in Chapter V. Following the qualitative approach in NIST SP 800-30 (Joint Task Force Transformation Initiative, 2012) and ISO/IEC 27005 (ISO/IEC, 2022), each risk was rated for likelihood and impact on a five-point scale, and the risk score is the product of the two ratings (Likelihood x Impact), giving a score from 1 to 25.

a. Risk Identification

Table 6.1 presents the ten risks identified from the assets, threats, and vulnerabilities in Chapter V. Each risk is linked to the asset, threat, and vulnerability behind it, the possible consequence if it occurs, and the existing controls the office already has in place. These risks are rated for likelihood and impact in the next sections.

Table 6.1

Identified Risks

Risk ID	Risk	Asset	Threat	Vulnerability	Possible Consequence	Existing Controls
R-01	Unauthorized access to the repository or SDU email	A-01 to A-10, mainly A-04, A-06, A-09, A-10	T-01, T-02	V-01, V-02, V-03, V-04	Disclosure or changes of sensitive records	Repository general access is Restricted; two-step verification appears sometimes
R-02	Disclosure or change of records by users with excessive access	A-03, A-04, A-06, A-09, A-10	T-02	V-02, V-07	Confidentiality and integrity loss; no accountability	Restricted general access; each office has access only to its own email
R-03	Theft or viewing of paper records, keys, and written credentials	A-04, A-06, A-09; credential paper file	T-03	V-01, V-11	Data disclosure; account takeover	Office door lock; visitor log; locked cabinet (keys lost); original key held by the admin officer
R-04	Loss or theft of a device with saved	Files on devices;	T-04	V-01, V-04,	Account takeover;	Borrower's logbook; reporting to the admin officer and the

Risk ID	Risk	Asset	Threat	Vulnerability	Possible Consequence	Existing Controls
	sessions or credentials	logged-in accounts		V-05, V-11	exposure of local files	Purchasing Custodian Office
R-05	Accidental disclosure through wrong recipients or personal channels	A-02, A-04, A-06, A-07, A-09	T-05	V-06, V-09, V-10	Confidential files reach unintended people	Restricted Drive sharing; data privacy notice on evaluations and surveys
R-06	Loss or misplacement of records	A-01 to A-10	T-06	V-08, V-09, V-12	Records cannot be found; operations delayed	Scanning paper files into the repository; chronological binders
R-07	Malware infection of office computers	Files on office computers and synced Drive	T-07	V-05, V-10	Data corruption or theft; downtime	Institutional network (university-managed; not verified by the audit)
R-08	Permanent loss of digital records without a working backup	A-01 to A-10 (digital)	T-06, T-10	V-08, V-09	Loss of availability; records not recoverable	Google provider storage; scanned copies; paper originals
R-09	Damage to paper records by fire, flood, or environment	Paper originals	T-09	V-12	Permanent loss of paper originals	Scanned copies in the repository
R-10	Loss of files stored only on an office computer	Locally saved files	T-08	V-06, V-08	Loss of locally stored files	Repository copies when files are uploaded

Table 6.1 lists the ten risks identified from the interaction of assets, threats, and vulnerabilities, together with the possible consequences and the controls already in place. In this assessment, a risk is the chance that a threat will use a vulnerability to harm an asset, so each risk below is built from one or more rows of Table 5.3 (Joint Task Force Transformation Initiative, 2012). The existing controls are listed because a control that already works lowers the likelihood or impact of a risk, while a control that is missing or only informal does not.

b. Likelihood Assessment

Likelihood is the chance that a threat will exploit a vulnerability within the next year, given the current controls and past incidents. Table 6.2 defines the five-point scale.

Table 6.2

Likelihood Scale

Rating	*Level*	*Description*
1	Rare	Not expected to occur; no past incident and strong controls
2	Unlikely	Could occur but not expected; some controls exist
3	Possible	May occur; controls are partial or informal
4	Likely	Expected to occur; weak controls or a past incident exists
5	Almost certain	Occurs regularly; no effective controls

Table 6.2 sets out the five-point likelihood scale used for every risk in this chapter. Each rating has a level name and a description based on how strong the controls are and whether a similar incident has already happened. A rating of 1 (Rare) is given only where controls are strong and no incident is known, while a rating of 5 (Almost certain) is for events that already happen regularly with no effective control. The middle ratings depend on the evidence from the interview. A missing control or a past incident raises a rating to 4 (Likely), while partial or informal controls give a 3 (Possible). Using one scale for all risks keeps the ratings in Table 6.3 consistent and makes each rating easy to check against the evidence.

Table 6.3

Likelihood Ratings

Risk ID	*Likelihood*	*Justification*
R-01	4 (Likely)	Shared accounts, credentials on paper and notes, no password policy, inconsistent two-step verification
R-02	3 (Possible)	Many office accounts have Editor access; access removal is informal
R-03	3 (Possible)	Visitors can see computers; each staff has a spare key; cabinet keys lost
R-04	4 (Likely)	Devices have already been lost to other offices; saved devices skip two-step verification
R-05	3 (Possible)	Files are shared by email and Messenger links; no training or procedure
R-06	4 (Likely)	Files were misplaced or mistaken for trash in the past
R-07	3 (Possible)	No security software on the office computers
R-08	2 (Unlikely)	Google storage is reliable, but deletion or lockout is possible and no restore test exists
R-09	2 (Unlikely)	Rare event, but no protection was reported
R-10	2 (Unlikely)	Possible hardware failure; most files are also in the repository

As shown in Table 6.3, R-01, R-04, and R-06 received the highest likelihood rating (4) because the interview gives direct support for them: shared accounts with credentials kept on paper and in notes, devices that were lost in the past, and files that were misplaced (Q12, Q14, Q22). R-02, R-03, R-05, and R-07 were rated 3 (Possible) because the controls are partial or informal, but no past incident was reported. R-08, R-09, and R-10 were rated 2 (Unlikely) because the events are less common or because copies of the records exist elsewhere.

C. Impact Assessment

Impact is the harm to the office if the risk occurs, considering confidentiality, integrity, availability, operations, finances, legal obligations (including the Data Privacy Act of 2012), and reputation. Table 6.4 defines the five-point scale.

Table 6.4

Impact Scale

Rating	*Level*	*Description*
1	Negligible	No real effect on operations; easily corrected
2	Minor	Small delay or rework; no sensitive data exposed
3	Moderate	Noticeable operational delay or limited exposure of internal data
4	Major	Exposure of sensitive data or serious disruption; possible legal or reputational concern
5	Severe	Large-scale exposure or permanent loss of critical records; legal, financial, and reputational damage

Table 6.4 sets out the five-point impact scale. The ratings run from 1 (Negligible) to 5 (Severe) and consider the harm to confidentiality, integrity, and availability, as well as the effect on operations, finances, legal obligations such as the Data Privacy Act of 2012, and the reputation of the office. The classification of assets in Table 3.3 was also considered, since the exposure or loss of an asset rated High there is more serious than that of an asset rated Low. A risk that exposes sensitive records or destroys the main store of records is therefore rated higher than one that affects a single computer or a small set of files. The ratings for each risk are shown in Table 6.5.

Table 6.5

Impact Ratings

Risk ID	*Impact*	*Justification*
R-01	5 (Severe)	Finance documents, agreements, strategic plans, and staff records could be exposed or changed; the office handles personal data covered by the Data Privacy Act of 2012
R-02	4 (Major)	Sensitive files can be viewed or changed without traceability
R-03	4 (Major)	Written credentials could give access to accounts and records
R-04	4 (Major)	A lost device with a saved session could open the shared account and repository

Risk ID	*Impact*	*Justification*
R-05	3 (Moderate)	Exposure is limited to the files shared by mistake
R-06	3 (Moderate)	Operations are delayed; scanned copies reduce the loss
R-07	3 (Moderate)	Downtime and possible data loss on the affected computer
R-08	5 (Severe)	The repository is the main digital store; born-digital reports and plans could be lost permanently
R-09	3 (Moderate)	Scanned copies exist for many records, but originals such as agreements would be lost
R-10	2 (Minor)	Most files are also in the repository

As shown in Table 6.5, R-01 and R-08 received the highest impact rating (5) because they involve the whole repository, which holds the financial documents, formal agreements, strategic plans, and staff records. R-02, R-03, and R-04 were rated 4 (Major) because they could expose sensitive records or give access to the shared account. Risks limited to one computer or to a small set of files, such as R-10, received lower ratings because the same files are usually also in the repository.

d. Risk Rating

The risk score is the likelihood rating multiplied by the impact rating. Scores were grouped into three levels: Low (1 to 5), Moderate (6 to 14), and High (15 to 25). Table 6.6 shows the resulting risk assessment matrix.

Table 6.6

Risk Assessment Matrix

Likelihood / Impact	*1 Negligible*	*2 Minor*	*3 Moderate*	*4 Major*	*5 Severe*
5 Almost certain	5 Low	10 Moderate	15 High	20 High	25 High
4 Likely	4 Low	8 Moderate	12 Moderate	16 High	20 High
3 Possible	3 Low	6 Moderate	9 Moderate	12 Moderate	15 High
2 Unlikely	2 Low	4 Low	6 Moderate	8 Moderate	10 Moderate
1 Rare	1 Low	2 Low	3 Low	4 Low	5 Low

Table 6.6 shows how a risk score is read. The rows are the likelihood ratings and the columns are the impact ratings, and each cell is the product of the two with its risk level. For example, R-01 has a likelihood of 4 and an impact of 5, which gives a score of 20 and a High level, while R-10 has a likelihood of 2 and an impact of 2, which gives a score of 4 and a Low level. Scores of 15 to 25 are High and need immediate action, scores of 6 to 14 are Moderate and need planned action, and scores of 5 or below are Low and can be monitored. Because the score is a product, a risk must be at least moderately likely and have a major impact to reach the High level, and the same score from different combinations, such as 3 x 4 and 4 x 3, receives the same level.

Table 6.7

Risk Ratings

Risk ID	*Risk*	*Likelihood*	*Impact*	*Score*	*Risk Level*
R-01	Unauthorized access to the repository or SDU email	4	5	20	High
R-04	Loss or theft of a device with saved sessions or credentials	4	4	16	High
R-02	Disclosure or change of records by users with excessive access	3	4	12	Moderate
R-03	Theft or viewing of paper records, keys, and written credentials	3	4	12	Moderate
R-06	Loss or misplacement of records	4	3	12	Moderate
R-08	Permanent loss of digital records without a working backup	2	5	10	Moderate
R-05	Accidental disclosure through wrong recipients or personal channels	3	3	9	Moderate
R-07	Malware infection of office computers	3	3	9	Moderate
R-09	Damage to paper records by fire, flood, or environment	2	3	6	Moderate
R-10	Loss of files stored only on an office computer	2	2	4	Low

Table 6.7 ranks the ten risks from the highest score to the lowest. R-01 has the highest score (20), followed by R-04 (16), and both are High because accounts and devices that are shared, saved, or not protected give a way into all of the office's digital records. Seven risks are Moderate, with scores from 6 to 12. Three of them (R-02, R-03, and R-06) share the same score of 12 but for different reasons: R-02 and R-03 are driven by their impact on sensitive records, while R-06 is driven by its likelihood, since files have already been misplaced. R-10 is the only Low risk (4) because it affects files that are usually also in the repository. The two High risks should be treated first in Chapter VIII, followed by the Moderate risks in order of score.

e. Risk Register

The results of the risk identification, likelihood assessment, impact assessment, and risk rating are consolidated in the risk register in Table 6.8. It lists each risk with its asset, threat, vulnerability, likelihood, impact, score, and level, so the risks can be compared in one place. The register serves as the reference for the audit findings and recommendations in the next chapters.

Table 6.8

Risk Register

Risk ID	*Asset*	*Threat*	*Vulnerability*	*Likelihood*	*Impact*	*Score*	*Level*
R-01	A-01 to A-10 (mainly A-04, A-06, A-09, A-10)	T-01, T-02	V-01, V-02, V-03, V-04	4	5	20	High
R-02	A-03, A-04, A-06, A-09, A-10	T-02	V-02, V-07	3	4	12	Moderate
R-03	A-04, A-06, A-09; credential paper file	T-03	V-01, V-11	3	4	12	Moderate
R-04	Devices with saved sessions	T-04	V-01, V-04, V-05, V-11	4	4	16	High
R-05	A-02, A-04, A-06, A-07, A-09	T-05	V-06, V-09, V-10	3	3	9	Moderate
R-06	A-01 to A-10	T-06	V-08, V-09, V-12	4	3	12	Moderate
R-07	Files on office computers	T-07	V-05, V-10	3	3	9	Moderate
R-08	A-01 to A-10 (digital)	T-06, T-10	V-08, V-09	2	5	10	Moderate
R-09	Paper originals	T-09	V-12	2	3	6	Moderate
R-10	Locally saved files	T-08	V-06, V-08	2	2	4	Low

Table 6.8 gathers the ten risks in one register. Each row shows the asset, the threat, and the vulnerability behind the risk, so the risk can be traced back to Tables 5.1 to 5.3, and shows its likelihood, impact, score, and level, so it can be traced to Tables 6.3, 6.5, and 6.7. R-01 and R-04 are the High risks, followed by the Moderate risks in order of score. The register is the basis for the audit findings in Chapter VII, where each finding is linked to the risks it creates, and for the risk treatment in Chapter VIII. The register should also be reviewed after the recommended controls are put in place, because the likelihood and impact ratings, and therefore the scores, would be expected to change.

VII. Audit Findings

This section presents the significant findings of the audit. The findings were taken from the risk register in Chapter VI and traced back to the vulnerabilities in Chapter V and the existing controls in Chapter IV. A finding is considered significant when it is linked to a High or Moderate risk or when it affects an asset rated High in Table 3.3. The six findings are discussed below under eight headings: summary of the findings, significant findings, the evidence that supports each finding, why it is significant, the assets affected, the risks it creates, why the weakness exists, and what could happen if it is exploited. Details already presented in Chapters IV to VI are mentioned only where they are needed to explain a finding. The questionnaire items (Q1 to Q25) are in Appendix B, the checklist is in Appendix C, and the repository screenshots are in Appendix D.

a. Summary of Findings

Table 7.1 summarizes the six findings, the vulnerabilities from Table 5.2 and the risks from Table 6.8 that each one is based on, and the level of each finding. The level of a finding is the level of the highest-rated risk linked to it.

Table 7.1

Summary of Audit Findings

Finding ID	*Finding*	*Related Vulnerabilities*	*Related Risks*	*Risk Level*
F-01	Office accounts rely on shared and unsecured credentials	V-01, V-02, V-03, V-04	R-01	High
F-02	Devices and personal accounts used for office work are not protected	V-05, V-06	R-04, R-05, R-07	High
F-03	Access to the shared repository is broad and informally managed	V-02, V-07	R-02	Moderate
F-04	Physical access to paper records and keys is not tightly controlled	V-01, V-11, V-12	R-03, R-09	Moderate
F-05	Security policies, training, and incident procedures are missing	V-09, V-10	R-05, R-06	Moderate
F-06	There is no independent backup and no restore test	V-08	R-08, R-10	Moderate

Table 7.1 shows two High findings (F-01 and F-02), both about how accounts and devices are protected, and four Moderate findings about access management, physical protection, missing policies and training, and backup. Together the six findings cover all twelve vulnerabilities in Table 5.2. The findings are listed from the highest-rated risk to the lowest, so the first two should receive attention first.

b. Significant Findings

F-01. The office's digital records rely heavily on the SDU Centralized Repository and institutional Google accounts. However, several weaknesses were identified in account security. Institutional email accounts are shared among staff within their respective offices, while login credentials are kept in a paper file and in notes on personal devices. The office also has no established password requirements, and two-step verification is not required when a device has already been saved in the account.

F-02. Staff use personal devices and personal email accounts for office-related work, and files are shared through email and links sent via Messenger. The office computers do not have antivirus or other security software installed, while security software is installed on the personal devices used for work. However, no specific requirement for device security was reported. The respondent also expressed concern that some information may be stored in personal accounts or on office computers instead of the designated repository.

F-03. The SDU Centralized Repository is owned by the SDO office account, and its main folder is shared with several unit and individual accounts, all of which have Editor access. General access is set to "Restricted." According to the respondent, when a staff member leaves, the remaining staff remove that person's access. However, no written procedure for reviewing and managing account permissions was identified.

F-04. The office has locks, a locked cabinet, and a visitor log as part of its physical security practices. Each staff member keeps a spare key, while the original key is held by the Admin Officer. However, the respondent reported that a cabinet key had been lost, and no information was provided about the cabinet's contents. No record of key assignments was reported. The office also has no CCTV cameras, and visitors can see the computers inside the office. Paper records are stored in binders and retained for 10 to 15 years before disposal, depending on their importance. The office has also experienced incidents involving misplaced documents and records mistaken for trash. No fire or flood protection measures were reported during the audit.

F-05. The only written policy mentioned by the respondent is a data privacy statement used for evaluations and surveys. No written procedures were identified for password management, access control, acceptable use, incident response, or physical security. The respondent also stated that staff had not received information security training so far. When problems occur, staff report them to the Office Head or Unit Director. Scanned copies are used as references when paper records are misplaced, while the borrower's logbook is checked to help trace devices borrowed by other offices.

F-06. The SDU Centralized Repository serves as the only and main digital storage location for the office's records. Paper documents are scanned and uploaded to the repository, and the respondent also mentioned that a scanned copy is kept on one office computer. However, no separate backup location or formal backup arrangement was reported. The office has also not tested whether its stored files can be successfully restored.

C. Evidence supporting the findings

F-01. The office lacks consistent account security practices. Login credentials are kept in a paper file and notes on personal devices, no formal password requirements are established, and two-step verification is not consistently required (Q12–Q14). These weaknesses correspond to V-01 to V-04 in Table 5.2.

F-02. The use of personal devices and email accounts for office-related work, together with the absence of security software on office computers, creates additional concerns regarding the protection of office information (Q10, Q11, Q24). Previous incidents involving borrowed devices that were not returned were also reported (Q22). These findings relate to V-04, V-05, V-06, and V-11 in Table 5.2. However, the audit did not include technical testing to verify the effectiveness of the security software installed on personal devices.

F-03. Although the repository's general access is restricted, several accounts have Editor access to its main folder (Table 4.1). The permissions of the APC subfolder could not be verified from the available screenshots. Furthermore, no written access control procedure was identified (Q12; Table 4.2). These findings correspond to V-02 and V-07 in Table 5.2.

F-04. The audit identified concerns regarding the physical protection of office records and equipment, including the reported loss of cabinet keys, the absence of CCTV cameras, and the visibility of computers to visitors (Q18, Q19). Previous incidents involving misplaced records were also reported (Q22). These findings correspond to V-11 and V-12 in Table 5.2.

F-05. The office has limited documented information security policies and practices. The only written policy reported was a data privacy statement for evaluations and surveys (Q20). The respondent also confirmed that staff had not received information security training ("None so far," Q21) and that incidents are handled through informal reporting practices (Q22). These findings correspond to V-09 and V-10 in Table 5.2.

F-06. The office has not verified whether its stored files can be successfully restored in case of data loss, as no restoration test has been conducted (Q15, Q16). This corresponds to V-08 in Table 5.2.

d. Significance of the Findings

F-01. Each of these weaknesses may seem manageable on its own, but together they increase the risk of unauthorized access to the repository. Keeping credentials in a paper file and notes on personal devices makes them more vulnerable to being discovered, while the inconsistent use of two-step verification provides less protection when signing in from saved devices. Since office accounts are shared among staff, it may also be difficult to identify which individual accessed the account if an incident occurs. These weaknesses raise concerns regarding the protection of personal information under Section 20 of the Data Privacy Act of 2012, which requires reasonable and appropriate security measures.

F-02. The Restricted setting of the repository helps control access to files stored within it, but it does not provide the same protection to copies that may be handled through personal devices, personal email accounts, or messaging applications. Without clear guidelines on how office information should be handled outside the repository, staff may follow different practices when storing and sharing files. This creates uncertainty about where office information is kept and how it is protected. This finding is also related to F-01, since the use of saved devices and shared accounts may increase the risk of unauthorized access if a device is lost or accessed by another person.

F-03. While F-01 and F-02 focus on account security and the handling of information, this finding concerns the permissions granted to accounts that can access the repository. The Restricted setting limits general access, but it does not determine what each permitted account can do. Accounts with Editor access may modify or delete files, whether intentionally or by mistake. Furthermore, without a documented access control procedure, there is less assurance that permissions are regularly reviewed and updated when staff responsibilities change or when someone leaves the office.

F-04. Physical security concerns are also important because information can be exposed without an attacker accessing the office's digital accounts. Unauthorized entry into the office may allow someone to view or take paper records, equipment or other sensitive materials. The reported loss of a cabinet key also raises concerns about the security of records stored inside the cabinet. Although scanned copies have helped the office refer to misplaced paper records, they do not replace the need to protect the original documents. This is particularly important for records such as formal agreements, which may still require their original physical copies.

F-05. The lack of documented information security policies and procedures contributes to several of the weaknesses identified in the other findings. These include the absence of password requirements in F-01, acceptable-use guidelines in F-02, formal access control procedures in F-03, documented physical security procedures in F-04, and backup procedures in F-06. Without clear written guidelines, the implementation of security practices relies heavily on staff following existing informal procedures consistently. These practices may become inconsistent when responsibilities change or staff members leave the office.

F-06. Storing files in Google Drive and keeping scanned copies of paper records provide the office with ways to retain and refer to its information. However, the absence of restoration testing means that the office has not verified whether its stored files can be successfully recovered when needed. In the event of accidental deletion, file corruption, or loss of access, the office may experience difficulty retrieving important records. This highlights the importance of maintaining reliable backup copies and regularly testing whether they can be restored.

e. Information Assets Affected

F-01. This finding affects the accounts used to access the digital copies of all ten information assets (A-01 to A-10). The assets with the most at stake are Staff Records (A-04), Financial Documents (A-06), Formal Agreement (A-09), and Strategic Plans (A-10), which are rated High for both confidentiality and integrity in Table 3.3.

F-02. This finding affects the handling of office information through personal devices, office computers, personal email accounts, and file-sharing channels such as email and Messenger. The information assets identified in R-05 include the External Partner Inventory (A-02), Staff Records (A-04), Financial Documents (A-06), Formal Correspondence (A-07), and Formal Agreements (A-09).

F-03. The finding affects the Monitoring and Evaluation Reports (A-03), Staff Records (A-04), Financial Documents (A-06), Formal Agreements (A-09), and Strategic Plans (A-10). All five are rated High for integrity in Table 3.3, and four of them (A-04, A-06, A-09, A-10) are also high for confidentiality.

F-04. This finding affects the paper copies of Staff Records (A-04), Financial Documents (A-06), and Formal Agreements (A-09), as well as the paper file containing written login credentials. In the event of fire, flooding, or similar damage, the paper originals of all ten information assets may also be affected. The finding also concerns the physical security of office keys, cabinets, and equipment.

F-05. The finding affects all ten information assets because the missing policies and information security training affects how staff handle and protect office information. The assets identified in R-05 and R-06 are among those most directly exposed, while the assets rated High in Table 3.3 (A-03, A-04, A-06, A-09, and A-10) may have more serious consequences if their security is compromised.

F-06. The finding affects the digital copies of all ten information assets (A-01 to A-10), with Financial Documents (A-06) as the most important because it is the only asset rated High for availability. The files saved only on the office computer (R-10) are also affected.

f. Risks Created from the Findings

F-01. Weak account security increases the possibility of unauthorized access to institutional accounts and the SDU Centralized Repository (R-01), which is rated High. This concern is associated with the sharing of institutional accounts among staff and the storage of account credentials in physical files and notes on personal devices. If these credentials are accessed by unauthorized individuals, they could be used to gain entry to the office's digital records, potentially exposing confidential information. Additionally, the use of shared accounts

makes it more difficult to determine which individual accessed an account or its stored files when a security incident occurs.

F-02. The APC's reliance on personal devices and accounts for work-related activities, along with the lack of security software on office computers, creates several potential security risks. These include the loss or theft of devices with saved sessions or credentials (R-04), classified as High; accidental disclosure of office information (R-05), classified as Moderate; and malware infection of office computers (R-07), also classified as Moderate. A lost or stolen device may expose saved account credentials and locally stored office files to unauthorized individuals. In addition, sharing files through personal accounts and messaging applications may result in information being disclosed to unintended recipients. The absence of security software on office desktop computers further increases the likelihood of malware infections, which may affect the devices and the information they contain or access.

F-03. The lack of proper control and regular monitoring of repository permissions increases the risk of unauthorized modification or deletion of office records (R-02), which is classified as Moderate. Several unit and individual accounts have Editor access to the repository's main folder, giving them the ability to modify or delete files. If these permissions are retained even after they are no longer needed, office records may be changed or removed by individuals without a valid reason to access them. Moreover, without a formal procedure for reviewing account permissions, unnecessary editing privileges may remain active. This could affect the accuracy, integrity, and availability of the APC's stored information.

F-04. The limited control over physical records and office keys creates the risks of unauthorized access, theft, or viewing of paper records (R-03), which is classified as Moderate, and damage to physical records caused by environmental incidents (R-09), also classified as Moderate. Since no record of key assignments is maintained and a cabinet key has been reported lost, unauthorized individuals may gain access to documents stored inside the cabinet. Moreover, past incidents involving misplaced documents indicate that physical records may be lost or improperly handled. The audit also found no reported fire or flood protection measures, raising concerns about the office's ability to protect these records from environmental damage. These conditions may compromise the confidentiality and availability of important physical information assets.

F-05. The APC does not have established written information security policies, formal staff training, or documented procedures for handling security incidents. These gaps contribute to the risks of accidental disclosure of office information (R-05) and loss or misplacement of records (R-06), both rated Moderate. Without clear guidelines, personnel may rely on their own practices when storing, handling, and sharing office documents, which can lead to inconsistent information security practices. The lack of formal incident-handling procedures may also delay the reporting and appropriate response to problems involving organizational records. As a result, the office may have difficulty ensuring that its information assets are consistently protected.

F-06. The lack of an independent backup arrangement and regular restoration testing exposes the APC to the risk of permanent loss of digital records without a working backup (R-08), rated Moderate, and loss of files stored only on an office computer (R-10), rated Low. Since the SDU Centralized Repository serves as the office's primary digital storage location and no separate backup arrangement was reported, an incident affecting the repository could result in the loss of files without available recovery copies. Moreover, because no restoration testing has been conducted, the office has no confirmed basis for determining whether its stored records can be successfully recovered when needed. These conditions may affect the availability and continuity of access to important office information.

g. Possible Impact if the Weaknesses Are Exploited

F-01. If exploited, a person who obtains a password through phishing (T-01) or finds it in the paper file (T-03) could access the repository using the compromised credentials. Depending on the account's permissions, they could view, modify, or delete files, including Financial Documents, Formal Agreements, Strategic Plans, and Staff Records. If staff personal information is accessed or exposed, this could raise concerns under the Data Privacy Act of 2012. If financial records are altered or deleted, office transactions could be disrupted and payments delayed.

F-02. If exploited, a lost or stolen device with an active saved session could allow another person to access the shared account without completing another verification step (T-04). If malware infects an office computer without security software, it could steal or damage files and potentially affect files synchronized with the repository (T-07). If files are sent to the wrong recipient or through personal communication channels (T-05), the office may have difficulty retrieving or controlling them afterward. If files remain in personal accounts after a staff member leaves, they may continue to be accessible outside the office's control.

F-03. If exploited, an account with unnecessary Editor access could be used to modify, overwrite, or delete important records, whether intentionally or by mistake (T-02). If a former staff member's access is not properly removed, the same actions could also be performed through that account. If unauthorized changes are made while accounts are shared, identifying the individual responsible may become difficult. As a result, errors or alterations in reports and financial documents could remain unnoticed until the records are needed.

F-04. If exploited, someone who enters the office while it is unattended could view or take paper records, office keys, or the written credentials (T-03). If the credentials are obtained, they could also be used to attempt unauthorized access to the office's digital accounts. If a fire or flood occurs (T-09), paper originals could be damaged or destroyed. If records are misplaced or borrowed equipment is not returned, office activities could also be disrupted, and staff may experience delays in accessing important information.

F-05. If exploited, the same errors, such as a misplaced file or a file sent to the wrong person, may repeat without being recorded, and recovery would again depend on whoever remembers what to do. An incident involving personal data would have no documented way of being reported or handled under the Data Privacy Act of 2012, and controls could lapse when a staff member leaves.

F-06. If exploited, accidental deletion (T-06), loss of account access, or account compromise (T-10) could make important digital records unavailable. If a shared account is compromised, as discussed in F-01, files accessible through that account could also be affected. If the scanned copies kept on the office computer are lost or damaged due to device failure or other incidents (T-08), the office may have difficulty recovering them. If file restoration is attempted for the first time during an emergency, the office may discover that the available copies cannot be recovered successfully. If important reports and plans are lost, office operations could be disrupted.

VIII. Recommended Security Improvements

This section presents the group's recommendations for addressing the information security risks identified in Chapter VI. It discusses how the Ateneo Peace Center (APC) should respond to each risk, the specific controls proposed to address the vulnerabilities found in Chapter V, and the order in which these controls should be implemented. The recommendations build on the existing controls described in Chapter IV and take into account the small size of the office, which has two APC staff supported by a shared Admin Officer. Most of the proposed controls therefore rely on tools the office already uses, such as its Google Drive repository and institutional email accounts, and on simple written procedures that the staff can carry out with little additional cost or technical expertise.

a. Risk Treatment

This subsection states how the office should respond to each risk in the risk register (Table 6.8). Four responses were considered: risk avoidance, which means stopping the activity that creates the risk; risk reduction or mitigation, which means adding or improving controls to lower the likelihood or impact; risk transfer, which means shifting the risk or its cost to another party, such as an insurer or a service provider; and risk acceptance, which means keeping the risk as it is and monitoring it (Whitman & Mattord, 2022; ISO/IEC, 2022). The response for each risk follows its level in Table 6.7: High risks need immediate action, Moderate risks need planned action, and Low risks can be monitored.

Table 8.1

Risk Treatment for the Identified Risks

Risk ID	*Risk*	*Risk Level*	*Treatment*	*Rationale*
R-01	Unauthorized access to the repository or SDU email	High (20)	Reduce/Mitigate	A password rule, secure storage of credentials, and required two-step verification address V-01 to V-04 and lower the likelihood of unauthorized access
R-04	Loss or theft of a device with saved sessions or credentials	High (16)	Reduce/Mitigate	Screen locks, signing out of shared accounts on devices, and a device record remove the saved-session shortcut and lower the likelihood and the impact of a lost device
R-02	Disclosure or change of records by users with excessive access	Moderate (12)	Reduce/Mitigate	A review of who has Editor access, and viewer-only access where editing is not needed, lowers the chance and the effect of misuse
R-03	Theft or viewing of paper records, keys, and written credentials	Moderate (12)	Reduce/Mitigate	Replacing the lost cabinet keys, recording who holds keys, and removing written credentials from paper lower the chance that records or credentials are taken
R-06	Loss or misplacement of records	Moderate (12)	Reduce/Mitigate	Continued scanning, a simple file handling rule, and a record of incidents lower the chance and the effect of lost files
R-08	Permanent loss of digital records without a working backup	Moderate (10)	Reduce/Mitigate	A separate backup copy and an occasional restore test lower the impact, since records can be recovered if the repository is lost
R-05	Accidental disclosure through wrong recipients or personal channels	Moderate (9)	Reduce/Mitigate	Short training and a rule to check the recipient or link before sending lower the likelihood of accidental disclosure
R-07	Malware infection of office computers	Moderate (9)	Reduce/Mitigate	Installing security software on the office computers and keeping it updated lowers the likelihood of infection
R-09	Damage to paper records by fire,	Moderate (6)	Reduce/Mitigate	Keeping scanned copies up to date and keeping the originals of critical

Risk ID	*Risk*	*Risk Level*	*Treatment*	*Rationale*
	flood, or the environment			documents in a locked cabinet is low in cost and lowers the impact
R-10	Loss of files stored only on an office computer	Low (4)	Accept	The risk is Low and most files are also in the repository, so added controls are not justified; the office should only monitor it and save files in the repository

As shown in Table 8.1, nine of the ten risks are reduced and only R-10 is accepted. Risk avoidance was not chosen because it would require the office to stop activities it depends on, such as storing records in Google Drive, sharing files by email and Messenger, or using personal devices when staff are out of town. Risk transfer was not chosen as the main response because the audit found no insurance or outsourced service for these records, and moving the risk to another party would not change the account and device habits that the office controls. Acceptance applies only to R-10 because it is the only Low risk. Several risks share the same vulnerabilities, for example V-01 and V-04 appear in R-01, R-03, and R-04, so one control can lower more than one risk. R-01 and R-04 are High and should be treated first.

b. Recommended Controls

This subsection presents the specific controls that the group recommends for the Ateneo Peace Center. Each control is intended to close a gap in the existing controls described in Chapter IV, and the controls are written to be practical for an office with two staff and a shared Admin Officer. They cover technology, policies and procedures, and physical measures, and they use the tools the office already uses wherever possible.

Table 8.2 presents the recommended controls. Each control is given an identification code (RC-01 to RC-13). The table links each control to the vulnerabilities in Table 5.2 that it addresses and the risks in Table 8.1 that it treats, and classifies it by type and function using the same categories as Table 4.3.

Table 8.2

Recommended Security Controls for the Ateneo Peace Center

ID	*Proposed Control*	*Description*	*Vulnerabilities Addressed*	*Risks Treated*	*Type / Function*
RC-01	Password guideline and password manager	Establish a written password guideline that requires staff to use long passphrases of at least 12 characters. Passwords should not be shared through chat or email, and credentials should no longer be stored in paper files or notes on personal devices. Instead, staff should use a password manager to store their credentials securely. Passwords should	V-01, V-03	R-01, R-03	Policy and Practice / Preventive

ID	*Proposed Control*	*Description*	*Vulnerabilities Addressed*	*Risks Treated*	*Type / Function*
		also be changed whenever a compromise is suspected or when a staff member who had access to them leaves the office.			
RC-02	Required two-step verification on institutional account	Coordinate with the university's IT office to enable mandatory two-step verification for the SDU Gmail account and all accounts with access to the repository, including when signing in from devices that have already been saved to the account.	V-04	R-01, R-4	Technology: Software / Preventive
RC-03	Repository access review	Review the accounts with access to the APC folders in the repository at least once every semester. Keep general access set to "Restricted," change Editor permissions to Viewer for accounts that do not need editing access, and remove accounts that no longer require access. Prioritize reviewing Staff Records (A-04), Financial Documents (A-06), Formal Agreements (A-09), and Strategic Plans (A-10).	V-07	R-01, R-02	Policy and Practice / Preventive and Detective
RC-04	Individual account and written offboarding checklist	Where possible, provide individual institutional email accounts for staff members instead of relying on shared office accounts. Establish a checklist for staff departures to ensure that access to the repository and relevant email accounts is reviewed and updated on the same day. Change shared passwords when necessary and ensure that office keys are returned.	V-02, V-07	R-01, R-02	Policy and Practice / Preventive
RC-05	Tested backup of important files	Maintain a second copy of the repository files in a separate storage location, starting with Financial Documents (A-06). This may be another storage account provided by the university or an external drive kept in a locked cabinet. Keep scanned copies of paper records updated and assign a staff member to maintain the backup. Test file restoration at least once every semester by recovering at least one file.	V-08	R-06, R-08, R-09	Technology and Policy and Practice / Corrective
RC-06	Safer file sharing	Share files from the repository through links restricted to specific recipients with Viewer access. Check the recipient list and link permissions before sending.	V-06, V-07	R-02, R-05	Policy and Practice / Preventive

ID	*Proposed Control*	*Description*	*Vulnerabilities Addressed*	*Risks Treated*	*Type / Function*
		Avoid sharing confidential documents through Messenger and use institutional email for official file exchanges.			
RC-07	Written acceptable-use and information security policy	Write a short policy on using personal devices and personal email for office work, keeping confidential files in the repository and not on personal devices or office computers, handling credentials, labeling confidential records, and a simple rule for saving and filing documents. Each staff member signs an acknowledgment.	V-06, V-09	R-04, R-05, R-10	Policy and Practice / Preventive
RC-08	Security software and automatic updates on office computers	Turn on the built-in antivirus and firewall of the operating system on the office computers and enable automatic updates, or ask the university's IT office to install its standard security software.	V-05	R-07	Technology: Software / Preventive
RC-09	Automatic screen lock and screen position	Set the office computers to lock after a few minutes of inactivity, and lock the screen when leaving the desk. Sign out of shared accounts when leaving a device. Place the screens so that visitors cannot read them.	V-11	R-04	Technology: Software / Preventive
RC-10	Written incident response procedure and incident log	Prepare a one-page procedure: report the incident to the office head or unit director on the same day and record it in an incident log. For lost devices, also inform the Admin Officer and the Purchasing Custodian Office. The unit director should consult the university's data privacy officer when personal data is involved.	V-09	R-04, R-06	Policy and Practice / Detective and Corrective
RC-11	Complete borrower's logbook and follow-up	Record every borrowed device with the borrower, the date, and the expected return date, and follow up on devices that are not returned. Check the spare computer sets in the cabinet against the logbook each semester.	V-11	R-04	Policy and Practice / Detective
RC-12	Key custody record and locked storage for key paper	Keep a record of who holds the spare keys and review it when staff change. Keep the paper originals of Staff Records (A-04), Financial Documents (A-06), and Formal Agreements (A-09) in the locked	V-11, V-12	R-03, R-06, R-09	Physical / Preventive and Detective

ID	*Proposed Control*	*Description*	*Vulnerabilities Addressed*	*Risks Treated*	*Type / Function*
	records	cabinet, and re-key or replace any cabinet whose keys were lost. Label the binders and keep them in a fixed place so that they are not misplaced or mistaken for trash.			
RC-13	Security awareness briefing	Hold a short briefing each semester and whenever new staff join, covering the password guideline, safe file sharing, the handling of personal data under the Data Privacy Act, and incident reporting.	V-10	R-05	Policy and Practice / Preventive

As presented in Table 8.2, the recommended controls address all twelve vulnerabilities identified in Table 5.2 and support the selected treatment for each of the ten risks in Table 6.8. Several recommendations make use of features that are already available to the office. For instance, Google Drive provides sharing settings that can be used for access reviews and safer file sharing (RC-03 and RC-06). The operating system also provides features such as screen locking, built-in antivirus protection, and automatic updates (RC-08 and RC-09), while two-step verification can be enabled to provide additional protection for institutional accounts (RC-02). Since these features are already available, implementing the recommendations may require little additional cost, although assistance from the university's IT office may be needed for RC-02 and RC-08.

Other recommendations address specific practices identified during the audit. The password guideline (RC-01) provides staff with a standard for managing their credentials, addressing the reported practice of keeping login details in a paper file and notes on personal devices, as well as the absence of established password requirements. The proposed controls also introduce additional ways to detect security-related issues within the office (RC-03, RC-10, RC-11, and RC-12), addressing the limited detective controls discussed in Chapter IV.

Furthermore, the backup and incident response recommendations (RC-05 and RC-10) establish clearer procedures for protecting information and responding to data loss or other incidents. In particular, RC-05 addresses the need to verify whether stored files can be recovered, given that the office has not yet tested its backup recovery process. Lastly, Risk R-10 is accepted and will be monitored rather than treated with additional measures. Therefore, RC-07 is the only recommended control associated with this risk.

C. Prioritization of Recommended Controls

The recommended controls were prioritized by considering several factors, such as the risk ratings presented in Tables 6.7 (Risk Ratings) and 6.8 (Risk Register), their effectiveness in reducing the likelihood or impact of security incidents, estimated implementation costs, feasibility within the APC, urgency, and the level of coordination required with other university offices. The recommended controls presented in Table 8.2 were assessed using these factors to determine which measures require immediate implementation and which can be addressed at a later time. Based on the assessment, the controls were classified into three priority levels (Immediate, Short Term, and Long Term) as shown in Table 8.3.

Table 8.3

Prioritization of Recommended Controls

Priority	*Control*	*Risk Treated (Level)*	*Cost*	*Feasibility*	*Urgency*	*Rationale*
1 - Immediate (as soon as possible)	RC-01 Password guideline and password manager	R-01 (High), R-03 (Moderate)	Low	High	High	Promotes proper password management and helps prevent risks caused by weak, reused, or unsecured passwords
1 - Immediate (as soon as possible)	RC-02 Required two-step verification on institutional accounts	R-01 (High), R-04 (High)	None	High	High	Provides additional security for institutional accounts and helps prevent unauthorized access if account passwords are exposed or compromised
1 - Immediate (as soon as possible)	RC-03 Repository access review	R-01 (High), R-02 (Moderate)	None	High	High	Restricts access to Google Drive and other repositories to authorized personnel, ensuring that only appropriate account holders can view or manage stored files
1 - Immediate (as soon as possible)	RC-04 Individual accounts and written offboarding checklist	R-01 (High), R-02 (Moderate)	None	High	High	Prevents former personnel from retaining access to office accounts and files
1 - Immediate (as soon as possible)	RC-09 Automatic screen lock and screen positioning	R-04 (High)	None	High	High	Prevents unauthorized access to unattended office computers
1 - Immediate (as soon as	RC-11 Complete borrower's	R-04 (High)	Low	High	High	Improves monitoring and

Priority	*Control*	*Risk Treated (Level)*	*Cost*	*Feasibility*	*Urgency*	*Rationale*
possible)	logbook and follow-up					accountability for borrowed devices
2 - Short Term (within the next few months)	RC-05 Tested backup of important files	R-06 (Moderate), R-08 (Moderate), R-09 (Moderate)	Low	Medium	High	Provides recoverable copies of important records in case of data loss
2 - Short Term (within the next few months)	RC-06 Safer file sharing	R-02 (Moderate), R-05 (Moderate)	None	High	Medium	Helps prevent sensitive information from being unintentionally exposed through improper file sharing
2 - Short Term (within the next few months)	RC-08 Security software and automatic updates on office computers	R-07 (Moderate)	Low	Medium	Medium	Keeps office computers protected against malware and security threats by ensuring that security software is regularly updated
2 - Short Term (within the next few months)	RC-10 Written incident response procedure and incident log	R-04 (High), R-06 (Moderate)	None	Medium	Medium	Sets clear procedures for reporting security incidents and properly documenting the actions taken
2 - Short Term (within the next few months)	RC-12 Key custody record and locked storage for key paper records	R-03 (Moderate), R-06 (Moderate), R-09 (Moderate)	Low	High	Medium	Restricts unauthorized access to office keys and helps safeguard important physical records
3 - Long Term (within the review cycle)	RC-07 Written acceptable-use and information security policy	R-04 (High), R-05 (Moderate), R-10 (Low)	None	Medium	Medium	Provides clear and consistent rules for handling office information and using personal devices for

Priority	*Control*	*Risk Treated (Level)*	*Cost*	*Feasibility*	*Urgency*	*Rationale*
						work-related activities
3 - Long Term (within the review cycle)	RC-13 Security awareness briefing	R-05 (Moderate	None	High	Medium	Improves staff understanding of their security responsibilities and promotes proper handling of organizational information

As presented in Table 8.3, the first-priority controls focus on addressing the two High risks: R-01 (unauthorized access to the repository or SDU email) and R-04 (loss or theft of devices with saved sessions or credentials). These controls were placed at the highest priority because they can be implemented using existing account security settings, computer features, and office procedures. They generally require minimal or no additional expenses and do not involve extensive preparation. Their immediate implementation can help strengthen the protection of office accounts, files, and devices against unauthorized access.

The second priority covers controls intended to strengthen the APC's existing security practices and improve the protection of its information assets. These measures include proper file-sharing procedures, regular data backups, computer security updates, and established procedures for reporting security incidents. While some controls may require coordination with the university's IT office or additional preparation, they remain important in addressing the Moderate risks identified in the assessment. Their implementation can help prevent accidental information disclosure, reduce the risk of data loss, and protect office computers from potential security threats.

The third priority consists of measures that help establish and maintain proper information security practices among APC personnel. This includes creating a written acceptable-use and information security policy that outlines the proper handling of office information and the use of personal devices for work-related activities. Regular security awareness briefings are also recommended to remind personnel of their responsibilities and guide them in applying safe information-handling practices. These measures help promote consistency in daily operations and support the effectiveness of the other security controls.

The identified priority levels provide the APC with a basis for planning and carrying out the recommended security improvements. By giving attention to high-risk concerns first and implementing the other controls according to their urgency and feasibility, the office can make better use of its available resources. This approach can help reduce existing security risks, protect important information assets, and improve the office's overall information security practices.

References

Data Privacy Act of 2012, Republic Act No. 10173 (2012). https://www.officialgazette.gov.ph/2012/08/15/republic-act-no-10173/

International Organization for Standardization & International Electrotechnical Commission. (2022). *Information security, cybersecurity and privacy protection: Guidance on managing information security risks* (ISO/IEC Standard No. 27005:2022). https://www.iso.org/standard/80585.html

Joint Task Force Transformation Initiative. (2012). *Guide for conducting risk assessments* (NIST Special Publication 800-30, Rev. 1). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-30r1

National Institute of Standards and Technology. (2004). *Standards for security categorization of federal information and information systems (FIPS PUB 199).* U.S. Department of Commerce. https://doi.org/10.6028/NIST.FIPS.199

Whitman, M. E., & Mattord, H. J. (2022). *Principles of information security* (7th ed.). Cengage Learning.

Appendix A

Group Members Tasks

Name of Member	Tasks
Caparas, Jean Juliana S.	● Information Security Audit Checklist ● Section II (Organization Profile) ● Section III (Information Asset Inventory) ● Section VII (Audit Findings) ● Section VIII (Recommended Security Improvements) ● Appendices
Isirani, Shariff D.	● Communications ● Information Security Audit Questionnaire ● Section V (Threat and Vulnerability Identification) ● Section VI (Risk Assessment) ● Section VII (Audit Findings) ● Section VIII (Recommended Security Improvements)
Ubag, Dorothy T.	● Information Security Audit Checklist ● Section I (Introduction) ● Section IV (Existing Security Controls) ● Section VII (Audit Findings) ● Section VIII (Recommended Security Improvements) ● Appendices (B-D)

Appendix B

This appendix contains the information security audit questionnaire provided to the APC Program Coordinator on October 30, 2026.

a. **Information Security Audit Questionnaire (Blank Copy)**

Information Security Audit Questionnaire

CIT.017 Information Assurance and Security – Final Project
Ateneo de Zamboanga University, College of Science and Information Technology,
Computer Science Department
Prepared by: Shariff Isirani, Dorothy Ubag, Jean Caparas

Good day po, Ma'am Mary! Thank you for agreeing to be part of our project. This questionnaire will help us understand how your office handles its information, records, and tools. It is for class purposes only. We are not evaluating any person, only how information is handled. Please do not write actual passwords or personal data in your answers. You may skip any question you are not comfortable answering, and you may tell us if there is anything you would like us to leave out of the report. Short answers are fine. Please type your answers on the lines marked Answer:

Respondent Information
Name:
Position:
Office/Unit (official name):
Date answered:

A. ORGANIZATION PROFILE (Section II)
1. What is the official name of your office, and what does it stand for?
Answer:

2. Who is in your office and what are their roles? (An organizational chart is welcome if you have one.
Answer:

3. What are the main functions or services of your office?
Answer:

4. What are your most important business processes and the people involved based on each processes (e.g., training requests, partner coordination, reporting)? For each one, who is involved, what information is used, and what tool or system is used, and the specific inputs/outputs?
Answer:

B. INFORMATION ASSETS (Section III)
5. What kinds of information does your office keep (staff records, certificates, partner details, reports, evaluations, etc.)?
Answer:

6. Which of these are the most sensitive or important?
Answer:

7. Who owns or is responsible for each one?
Answer:

8. What would happen if each one were lost, leaked, changed by mistake, or unavailable for a few days?
Answer:

C. SYSTEMS AND TECHNOLOGY (Section II.c and III)
9. Where is each type of information stored (e.g., Google Drive, Google Forms, Excel files, email, Messenger, paper files, flash drives)?
Answer:

10. What computers, network, and email do you use? Are they office-owned or personal? Does anyone use personal devices or accounts for office work?
Answer:

11. Is there any antivirus, firewall, or other security software on the computers?
Answer:

D. ACCESS AND PASSWORDS (Section IV)
12. Who can access each system or folder? How is access given or removed when someone joins or leaves the office?
Answer:

13. Are accounts shared among staff? Do some staff have access to more than their job needs?
Answer:

14. Is there a password rule (e.g., length, how often it is changed)? Do you use two-step verification?
Answer:

E. BACKUP AND DATA HANDLING (Section IV)
15. Do you back up your files? How often, where, and who does it?
Answer:

16. Has anyone ever tried restoring a backup to check if it works?
Answer:

17. How are files shared inside and outside the office (e.g., email, Messenger, links)?
Answer:

18. How are paper documents stored and disposed of, and how long are records kept?
Answer:

F. PHYSICAL SECURITY (Section IV)
18. Is the office locked? Who has keys or access?
Answer:

19. Where are the computers and paper files kept? Can visitors see or reach them? Is there CCTV, a visitor log, or a locked cabinet?
Answer:

G. POLICIES, TRAINING, AND INCIDENTS (Section IV)
20. Is there a written policy for data privacy, acceptable use, or incident handling? If yes, may we have a copy?
Answer:

21. Have staff received training on data privacy or cybersecurity (e.g., the Data Privacy Act)?
Answer:

22. Has the office ever had a security incident, such as lost files, a hacked account, a message sent to the wrong person, or a lost device? What happened, and what was done?
Answer:

23. Who do staff report problems to?
Answer:

H. WRAP-UP
24. What worries you most about how information is handled in your office?
Answer:

25. Is there anything we did not ask that we should know?
Answer:

b. Accomplished Information Security Audit Questionnaire

Information Security Audit Questionnaire

CIT.017 Information Assurance and Security – Final Project
Ateneo de Zamboanga University, College of Science and Information Technology, Computer Science Department
Prepared by: Shariff Isirani, Dorothy Ubag, Jean Caparas

Good day po, Ma'am Mary! Thank you for agreeing to be part of our project. This questionnaire will help us understand how your office handles its information, records, and tools. It is for class purposes only. We are not evaluating any person, only how information is handled. Please do not write actual passwords or personal data in your answers. You may skip any question you are not comfortable answering, and you may tell us if there is anything you would like us to leave out of the report. Short answers are fine. Please type your answers on the lines marked Answer:

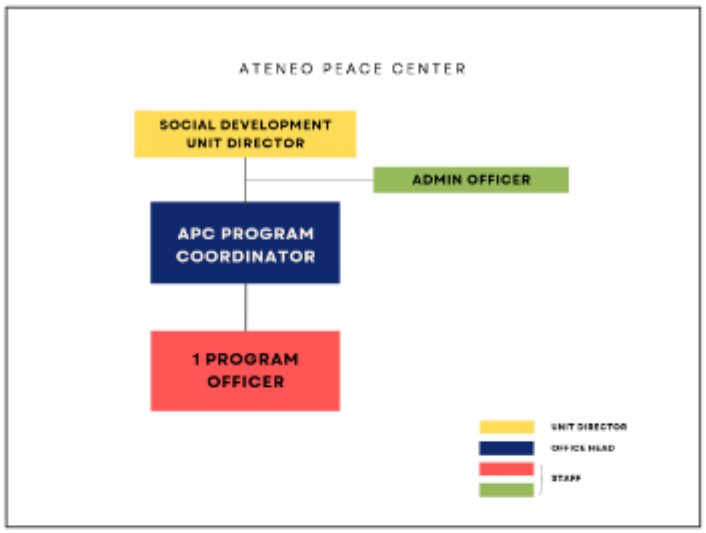
Respondent Information

Name: Mary Elizabeth S Apolonio
Position: Program Coordinator
Office/Unit (official name): Ateneo Peace Center/Social Development Unit
Date answered: October 30, 2026

A. ORGANIZATION PROFILE (Section II)
1. What is the official name of your office, and what does it stand for?
Answer: APC or Ateneo Peace Center (formerly it was Ateneo Peace Institute)

2. Who is in your office and what are their roles? (An organizational chart is welcome if you have one.)
Answer: Current personnel:

- Mary Elizabeth Apolonio, Program Coordinator
- Fatima Raiza Ibrahim, Program Officer



**Note that our Admin Officer is the Admin/Support staff of the Social Development Office for now.*

3. What are the main functions or services of your office?
Answer: The Ateneo Peace Center empowers communities to build lasting peace through peace advocacy and communication, peace education, and research. It aims to promote transformative peace building mechanisms rooted from Ignatian spirituality, cultural sensitivity, and open dialogue.
What we do:

- Peace Advocacy: The aim of this program is to strengthen more effective peace building and conflict transformation mechanisms and improve peace, order, and harmony within the Ateneo community and across local communities.
- Peace Education: The program aims to equip individuals with knowledge, skills, and attitudes to build a culture of peace. This includes integrating peace values into existing curricula and co-curricular activities across Basic and Higher Education levels; designing and delivering educational programs on conflict resolution, nonviolence, and human rights; and training educators and community leaders.
- SALAAM-AdZU Organization: The SALAAM-AdZU Organization is the student volunteer arm of the Ateneo Peace Center (APC) of the Ateneo de Zamboanga University. This program empowers students to dive deeper into the culture of peace, providing a platform for meaningful engagement with the Ateneo community and offering hands-on experience in peace-related activities.

6. Which of these are the most sensitive or important?
Answer: Monitoring and evaluation reports, finance-related documents, copies of formal agreements, and strategic plans

7. Who owns or is responsible for each one?
Answer: Monitoring and evaluation reports (as an office), finance-related documents (usually the admin officer), copies of formal agreements (usually the admin officer), and strategic plans (as an office)

8. What would happen if each one were lost, leaked, changed by mistake, or unavailable for a few days?
Answer: Some of our operations would be at risk.

C. SYSTEMS AND TECHNOLOGY (Section II.c and III)
9. Where is each type of information stored (e.g., Google Drive, Google Forms, Excel files, email, Messenger, paper files, flash drives)?
Answer: Paper files and Google Drive folder (repository)

10. What computers, network, and email do you use? Are they office-owned or personal? Does anyone use personal devices or accounts for office work?
Answer: Institutional (office) email and personal email. We also use our personal devices for office work, especially when we are out of town.

11. Is there any antivirus, firewall, or other security software on the computers?
Answer: In terms of our computer desk in the office, we do not have security software. But on our personal devices, we do have.

D. ACCESS AND PASSWORDS (Section IV)
12. Who can access each system or folder? How is access given or removed when someone joins or leaves the office?
Answer: For our office (APC), only APC staff. We usually have a paper file with our credentials. But we also have it stored in our notes on our personal devices (e.g., notes, notepad). For our SDU email, everyone (APC, ACLG, and SDO staff only) has access to the SDU Gmail account. Access is given the same as the APC. If someone leaves, it is usually those who are still employed in the office who removes their access to the account.

13. Are accounts shared among staff? Do some staff have access to more than their job needs?
Answer: Yes, they are shared among staff. We only have access to SDU email. But we do not have access to other offices' emails. For instance, APC does not have access to ACLG's Gmail account. The same goes for ACLG.

14. Is there a password rule (e.g., length, how often it is changed)? Do you use two-step verification?
Answer: We do not have a password rule. Sometimes two-step verification appears, but sometimes it does not appear, especially if the device is saved in the account.

E. BACKUP AND DATA HANDLING (Section IV)
15. Do you back up your files? How often, where, and who does it?
Answer: We only store them in our repository GDrive folder. For physical paper files, we usually scan them first and then upload the scanned copy to the repository. It is usually managed by our Admin Officer, Program Officer, and Program Coordinator,

16. Has anyone ever tried restoring a backup to check if it works?
Answer: None so far.

17. How are files shared inside and outside the office (e.g., email, Messenger, links)?
Answer: Through email and shared links through Messenger.

18. How are paper documents stored and disposed of, and how long are records kept?
Answer: We store them in our paper binder in chronological order. They are kept for 10-15 years; then they are shredded, but it still depends on their significance (how important they are to be kept).

F. PHYSICAL SECURITY (Section IV)
18. Is the office locked? Who has keys or access?
Answer: Yes, it has locks. Each staff member has a spare key. The original key is kept by our admin officer.

19. Where are the computers and paper files kept? Can visitors see or reach them? Is there

19. Where are the computers and paper files kept? Can visitors see or reach them? Is there CCTV, a visitor log, or a locked cabinet?
Answer: Computers that are currently in use are kept on our computer desk. For spare computer sets (e.g., monitor, UPS, CPU), we have a large cabinet for this inside the office. Visitors can see them. We do not have CCTV, but we do have a visitor log and a locked cabinet.

G. POLICIES, TRAINING, AND INCIDENTS (Section IV)
20. Is there a written policy for data privacy, acceptable use, or incident handling? If yes, may we have a copy?
Answer: We usually have data privacy for our evaluations or surveys.

21. Have staff received training on data privacy or cybersecurity (e.g., the Data Privacy Act)?
Answer: None so far.

22. Has the office ever had a security incident, such as lost files, a hacked account, a message sent to the wrong person, or a lost device? What happened, and what was done?
Answer: We have had some lost files and lost devices in the past. Documents were misplaced or were mistaken for trash. That's why it is really important to have a scanned copy stored on our computer. For our experience with lost devices, it was mainly due to other offices borrowing and not returning them. Sometimes we just track them if they have logged onto our borrower's logbook, and if not, we report it to our admin officer and the Purchasing Custodian Office.

23. Who do staff report problems to?
Answer: The office head/unit director

H. WRAP-UP
24. What worries you most about how information is handled in your office?
Answer: If it is stored in their personal institutional account and in computer desk files and not in the office account or repository.

25. Is there anything we did not ask that we should know?
Answer: None so far.

Appendix C

This appendix contains the audit checklist used during the information-gathering stage of the information security audit.

a. Information Security Audit Checklist (Blank Copy)

COMPUTER RELATED

Statement	Yes	No
Antivirus or security software is installed		
Office Wi-Fi is password-protected		
Only office-owned devices are used for work		
Printers/scanners are not left holding documents		
Screens lock automatically when left unattended		
A firewall is enabled on applicable computers or network devices		
Only authorized devices are used to access office information.		
Security software is regularly updated to detect new threats		

STAFF QUESTIONS RELATED

Statement	Yes	No
Important accounts use two-step verification		
Personal data is not shared through personal email/chat		
Staff can only access what they need for their work		
Someone is responsible for IT and computers		
Strong passwords are used for office accounts		
Data privacy or cybersecurity training is provided		
Computers are locked when left unattended		

DATA BACK UP AND RECOVERY RELATED

Statement	Yes	No
Important files are backed up regularly		
Backup copies are stored separately from the original files		
Backup copies are checked to ensure they can be restored		
Backup files are protected from unauthorized access		
Important records are protected from accidental modification		
Responsibilities for managing backups are clearly assigned		
Backup storage has sufficient space for important files		
Backup procedures are documented		
Recovery procedures are available in case of data loss		
Access to backup files is limited to authorized personnel		

PHYSICAL SECURITY RELATED

Statement	Yes	No
Important paper records are kept in secure storage		
The office is locked when no authorized personnel are present		
Cabinets containing confidential documents are locked when not in use		
Visitors are monitored when entering restricted office areas		
Keys to restricted areas are provided only to authorized personnel		
CCTV cameras are installed in important areas where necessary		
Visitors cannot freely access computers or confidential records		
A visitor log is maintained when required		
Paper records are protected against fire, flooding, and other environmental hazards		
Restricted storage areas are accessible only to authorized personnel		

b. Accomplished Information Security Audit Checklist

COMPUTER RELATED

Statement	Yes	No
Antivirus or security software is installed		/
Office Wi-Fi is password-protected	/ (we only have the AdZU WiFi)	
Only office-owned devices are used for work		/
Printers/scanners are not left holding documents	/	
Screens lock automatically when left unattended		/
A firewall is enabled on applicable computers or network devices		/
Only authorized devices are used to access office information.	/	
Security software is regularly updated to detect new threats		/

DATA BACK UP AND RECOVERY RELATED

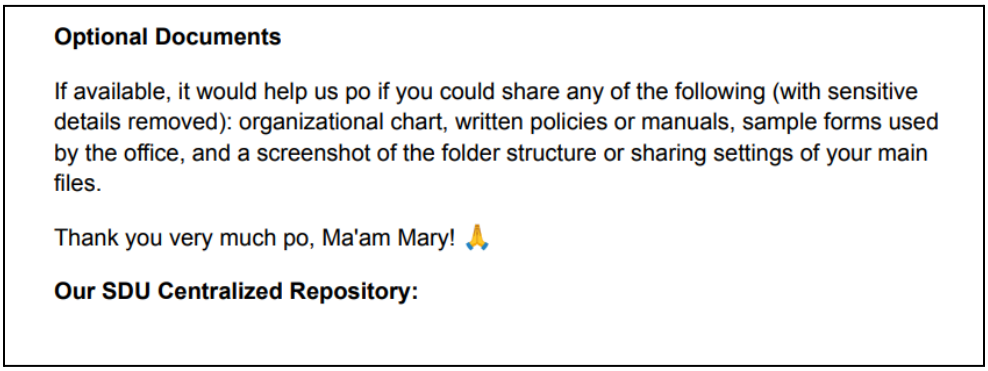
Statement	Yes	No
Important files are backed up regularly	/	
Backup copies are stored separately from the original files	/	
Backup copies are checked to ensure they can be restored		/
Backup files are protected from unauthorized access	/	
Important records are protected from accidental modification	/	
Responsibilities for managing backups are clearly assigned	/	
Backup storage has sufficient space for important files	/	
Backup procedures are documented		/
Recovery procedures are available in case of data loss		/
Access to backup files is limited to authorized personnel	/	

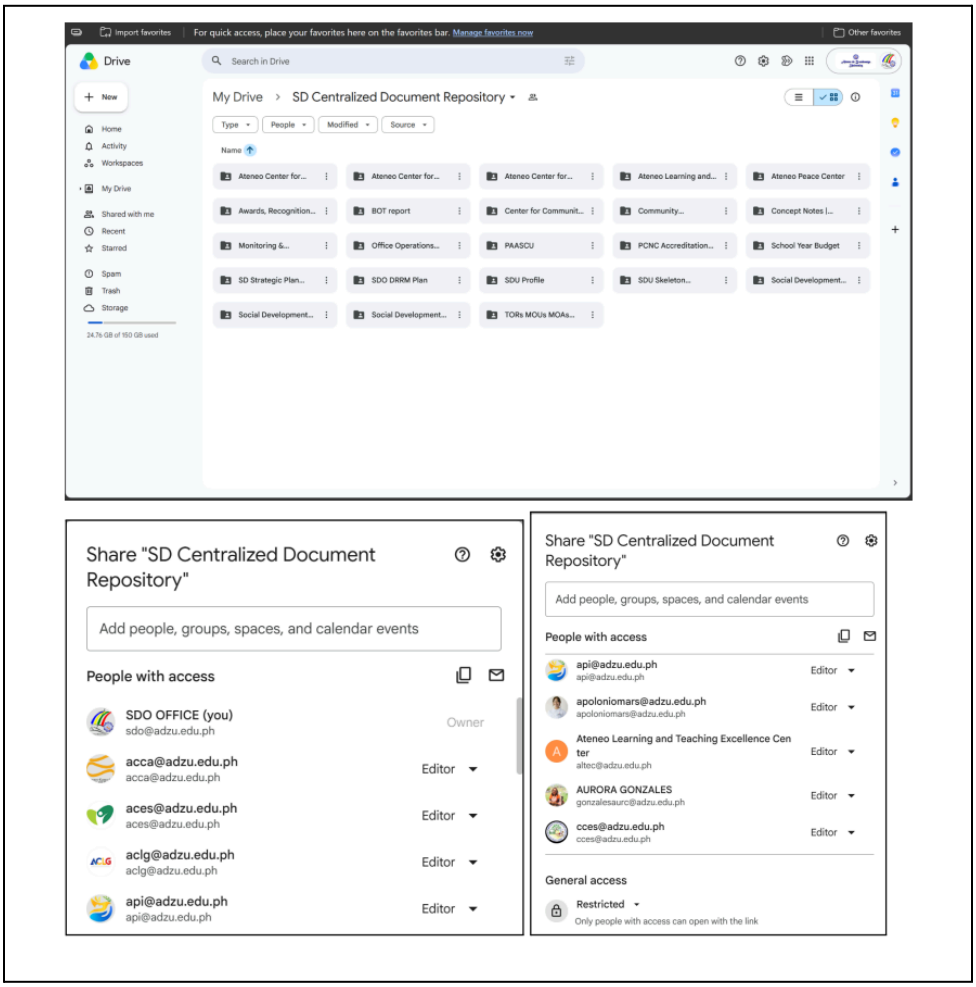
PHYSICAL SECURITY RELATED

Statement	Yes	No
Important paper records are kept in secure storage	/	
The office is locked when no authorized personnel are present	/	
Cabinets containing confidential documents are locked when not in use		/ (we lost the keys)
Visitors are monitored when entering restricted office areas	/	
Keys to restricted areas are provided only to authorized personnel	/	
CCTV cameras are installed in important areas where necessary	/ (but only outside of our office)	
Visitors cannot freely access computers or confidential records	/	
A visitor log is maintained when required	/	

Appendix D

This appendix contains supporting screenshots and materials provided by the APC Program Coordinator during the information-gathering stage. These materials include the SDU Centralized Repository's folder structure and sharing settings.




Drive
Search in Drive
My Drive
SD Centralized Document Repository
Share "SD Centralized Document Repository"
Add people, groups, spaces, and calendar events
People with access
SDO OFFICE (you)
sdo@adzu.edu.ph
Owner
acca@adzu.edu.ph
Editor
aces@adzu.edu.ph
Editor
aclg@adzu.edu.ph
Editor
api@adzu.edu.ph
Editor
apoloniomars@adzu.edu.ph
Ateneo Learning and Teaching Excellence Center
altec@adzu.edu.ph
AURORA GONZALES
gonzalesaurc@adzu.edu.ph
cces@adzu.edu.ph
General access
Restricted
Only people with access can open with the link